定西市明晖新能源有限公司信息系统安全等级测评报告

系统名称：功率预测系统

委托单位：定西市明晖新能源有限公司

测评单位：北京雅电科技有限公司

报告时间：2020 年 7 月 20 日

说明：

一、每个备案信息系统单独出具测评报告。

二、测评报告编号为四组数据。各组含义和编码规则如下：

第一组为信息系统备案表编号，由 2 段 16 位数字组成，可以从公安机关颁发的信息系统备案证明（或备案回执）上获得。第 1 段即备案证明编号的前 11 位（前 6 位为受理备案公安机关代码，后 5 位为受理备案的公安机关给出的备案单位的顺序编号）；第 2 段即备案证明编号的后 5 位（系统编号）。

第二组为年份，由 2 位数字组成。例如 09 代表 2009 年。

第三组为测评机构代码，由四位数字组成。前两位为省级行政区划数字代码的前两位或行业主管部门编号：00 为公安部，11 为北京，12 为天津，13 为河北，14 为山西，15 为内蒙古，21 为辽宁，22 为吉林，23 为黑龙江，31 为上海，32 为江苏，33 为浙江，34 为安徽，35 为福建，36 为江西，37 为山东，41 为河南，42 为湖北，43 为湖南，44 为广东，45 为广西，46 为海南，50 为重庆，51 为四川，52 为贵州，53 为云南，54 为西藏，61 为陕西，62 为甘肃，63 为青海，64 为宁夏，65 为新疆，66 为新疆兵团。90 为国防科工局，91 为电监会，92 为教育部。后两位为公安机关或行业主管部门推荐的测评机构顺序号。

第四组为本年度信息系统测评次数，由两位构成。例如 02 表示该信息系统本年度测评 2 次。

信息系统安全等级测评基本信息表

信息系统				
系统名称	功率预测系统		安全保护等级	S2A2G2
备案证明编号	—		测评结论	基本符合
被测单位				
单位名称	定西市明晖新能源有限公司			
单位地址	甘肃定西市安定区		邮政编码	743000
联系人	姓名	靳海	职务/职称	安全管理员
	所属部门	电力监控系统安防部	办公电话	—
	移动电话	18693515240	电子邮件	
测评单位				
单位名称	北京雅电科技有限公司		单位代码	
通信地址	北京市通州区运河商务区绿地中央广场二期1号楼1904		邮政编码	101100
联系人	姓名	朱泽巍	职务/职称	项目经理
	所属部门		办公电话	—
	移动电话	15691908171	电子邮件	—
审核批准	编制人		编制日期	
	审核人		审核日期	
	批准人		批准日期	

注：单位代码由受理测评机构备案的公安机关给出。

声　明

（声明是测评机构对测评报告的有效性前提、测评结论的适用范围以及使用方式等有关事项的陈述。针对特殊情况下的测评工作，测评机构可在以下建议内容的基础上增加特殊声明。）

本报告是功率预测系统的等级测评报告。

本报告测评结论的有效性建立在被测评单位提供相关证据的真实性基础之上。

本报告中给出的测评结论仅对被测信息系统当时的安全状态有效。当测评工作完成后，由于信息系统发生变更而涉及到的系统构成组件（或子系统）都应重新进行等级测评，本报告不再适用。

本报告中给出的测评结论不能作为对信息系统内部署的相关系统构成组件（或产品）的测评结论。

在任何情况下，若需引用本报告中的测评结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

单位名称（加盖单位公章）

2020 年 7月

等级测评结论

测评结论与综合得分			
系统名称	功率预测系统	**保护等级**	S2A2G2
系统简介	功率预测系统是按照电力行业等级保护及安全防护要求，由南瑞继保自动化股份有限公司设计、开发、以及销售和服务，。主要功能为实现光伏电站光功率预测系统的数据采集、存储和传输等功能。定西市明晖新能源有限公司将此次测评的“功率预测系统” 定级为第二级系统，并已由当地公安部门审核通过及出具系统定级备案证。		
测评过程简介	该项目自2020 年 7 月 10 日至 2020 年 7 月 24 日结束。测评过程分为前期准备、方案编制、现场测评和报告编制 4 个工作阶段。根据其定级备案材料， 确定该系统的基本测评指标为 S2A2G2。无特殊指标。 本次测评范围包括功率预测系统物理环境、网络、主机、业务应用系统、数据、安全管理制度和人员等等。安全测评通过静态评估、现场测试、综合评估等相关环节和阶段，从物理安全、网络安全、主机安全、应用安全、数据安全与备份恢复、安全管理制度、安全管理机构、人员安全管理、系统建设管理、系统运维管理等十个方面，对功率预测系统进行综合测评。		
测评结论	基本合格	**综合得分**	85.2

总体评价

通过本次等级保护测评，根据被测系统的测评结果和测评过程了解的相关信息，从以下几个方面评价定西市明晖新能源有限公司的“功率预测系统”的安全保护状况：

(1) 物理安全：机房位于升压站一楼，混凝土建筑可以有效防震、防风、防雨；机房 24 小时有人值守，进出机房需登记并由专人陪同；主要设备粘贴标签并放置在机房内，通信线缆铺设于地下，介质分类标记放在档案柜，机房安装视频监控和移动探测报警；机房建筑安装避雷装置；机房有火灾自动报警装置，无给排水管道， 屋顶、窗户已做防渗透措施；机柜配备防静电手环，并有接地线路；空调可保障机房温湿度；配备 UPS 作为短期备用电源设备，可满足 2 小时以上的供电需求；通信线路和电源线隔离铺设，不相互干扰。

(2) 网络安全：H3C 系列设备具有多业务并发处理能力，光口和电口的配置带宽可达到千兆，带宽和网络设备都可保证业务高峰期需求；网络拓扑标注设备 IP 地址并与实际情况相符合；各区域划分 vlan 并配置 IP 地址；网络安全监测装置可监测接入设备、安全事件及设备异常等信息，采用 IP-MAC 地址绑定方式防止未授权设备接入网络；边界路由器使用 ACL 控制列表进行访问控制；网络安全监测装置监测交换机、路由器运行状况、流量、用户行为等。

(3) 主机安全：在主机安全方面，操作系统启用了对管理用户的身份鉴别功能，通过“用户名+口令”的方式进行鉴别，系统资源满足当前业务使用需求。管理员设置的操作系统口令长度大于 8 位，至少包含字母、数字和特殊字符，但操作系统采用默认的口令策略。存在的问题有：未启用登录失败处理功能，未配置空闲会话超时时间限制，服务器中未安装防病毒软件等。

(4) 应用安全：功率预测系统的多用户权限控制设计实现登录控制模块，对登录用户进行身份标识及鉴别；用户口令采用 8 位以上大小写字母加数字形式且定期更换；不同账户分配了不同访问权限；纵向加密设备保证通信的保密性；提供多种保护机制，确保系统发生故障时自动保护当前状态。

(5) 管理方面：制定《系统安全防护制度》，包括门禁管理制度、人员管理制度、权限管理制度、设备维护管理制度、恢复与备份管理制度、培训管理制度、操作规程管理制度等。数字证书由电力公司统一下发、由安全主管统一管理。由定西市明晖新能源有限公司安全管理人员和操作人员对安全防护制度进行编写，相关领导进行审核，审核通过后以正式文件下发到相关人员手中。建立安全管理机构，由定西市明晖新能源有限公司总经理作为安全管理机构负责人，设立安全主管、系统管理员、网络管理员、安全管理员等岗位并明确相关职责。明确安全管理机构各部门职责，建立完善的制度审批流程。通过查看相关记录文件，了解该单位与行业信息安全监管部门已建成良好的沟通机制。通过访谈人事主管，由上级单位定西市明晖新能源有限公司行政人事部负责电站人员录用、离岗、考核和安全意识教育培训制度。由电站负责离岗人员访问权限收回，由上级单位行政人事部负责电站人员离岗工作并签署相关离职协议。外部人员访问机房需经过光伏电站主管人员审批并由专人陪同，并保留详细的来访登记记录。系统建设管理按电力行业要求，明确监控系统的边界和安全保护等级，定级按照电力行业标准和地调要求撰写定级报告，并通过定西市网安大队和地调的审核。系统在定级前已经按照风险评估结果进行相应整改并形成安全方案， 查阅安全方案的论证和审定记录，查阅相关专家论证意见和管理层批准意见。采购的安全产品通过电力行业认证检测，加密产品通过国家保密主管部门认证。查看该单位与外包软件开发商签订的相关协议，查看软件测试、验收和相关技术文档。查看实施方案、阶段性报告、安全测试报告、测试验收报告、系统交付清单符合要求。访谈安全主管，光伏发电站机房管理和办公环境管理符合二级等保相关规定。访谈资产管理员，查看相关的资产管理制度和资产清单都符合二级等保规定。访谈安全主管，该单位介质存放环境、使用、传输、维护和销毁等方面均符合《光伏发电站电力监控系统安全防护移动介质管理制度》的相关规定。访谈设备管理员，由电站填写《物资采购申请表》向上级单位申请，设备选型、采购、发放、使用、维护维修等方面均符合相关规定。访谈网络管理员，网络设备由公司统一进行更新，并在更新前对现有的重要文件进行备份。查看《光伏发电站电力监控系统安全防护远程访问管理制度》，网络外联有申请流程，需管理员和部门领导授权和批准。查看《年度信息安全培训计划》，该公司不定期开展恶意代码防范意识培训，《光伏发电站电力监控系统安全防护管理制度》规定外来计算机或存储设备

接入系统前必须经过病毒检查。访谈安全管理员，纵向加密设备使用均符合国家密码管理规定。访谈数据库管理员，光功率预测数据每隔两天进行一次数据备份，设备配置数据在设备安装时由厂商负责备份并交由厂站留存，其他数据不定期进行手动备份。查看《光伏发电站电力监控系统数据备份与恢复制度》，规定数据备份方式采用离线备份，关键数据至少两天备份一次，存储介质至少两份，备份数据永久保存。访谈安全主管，查看安全事件报告和处置过程记录及相关批准文档均符合相关标准。查看《应急预案汇编》，其内容包括应急预案的条件，应急处理流程，在确保信息系统可能发生的安全事件，在最短时间内得到妥善处置，将影响降低到最小。查看培训记录，对安全管理员，系统管理员和网络管理员每年至少举办一次应急预案培训，并形成培训记录。

(6) 在综合上述评价结果，该信息系统总体安全保护状况较好。功率预测系统等级测评结论为基本符合。

主要安全问题

根据测评结果和风险分析，存在的主要安全问题如下：

(1) 网络安全

1) 边界完整性检查：没有边界完整性检查如，入网准入设备；
2) 入侵防范：网络边界处没有入侵防如，IDS 等安全产品；
3) 网络设备防护：没有禁用 telnet 功能；
4) 网络设备防护：有管理员用户，但没有对登录地址进行限制；

(2) 主机安全

1) 身份鉴别：管理员设置了 8 位以上的大小写字母加数字的口令，但操作系统采用默认口令策略。
2) 身份鉴别：气象服务器终端采用默认的帐户锁定策略。
3) 入侵防范：气象服务器未遵循最小安装原则，安装了多余的程序或组件，而且未及时升级更新服务器的补丁，同时开放了多余的端口（如 135、445）。
4) 恶意代码防范：操作系统未安装防病毒软件。
5) 资源控制：未设置允许登录尝试次数、未设置锁定时间等策略。

(3) 应用安全

1) 身份鉴别：采取用户名+密码的方式进行登录，对用户身份进行鉴别，修改密码未设置密码复杂度策略；
2) 安全审计：未启用审计功能；
3) 通信保密性：系统没有对通信过程中的用户口令、会话密钥等敏感信息字段进行加密；
4) 资源控制：没有自动结束会话功能。

(4) 安全管理机构

1) 人员配备：未配备专职安全管理员；

(5) 系统建设管理

1）外包软件开发没有做恶意代码检测；

2）也没有做外包软件源代码备份留存。

(6) 系统运维管理

1) 网络安全管理：未指定人员对网络进行安全管理；未定期对网络系统进行漏洞扫描；未对网络设备的配置文件做离线备份；
2) 系统安全管理：未对系统进行漏洞扫描；未建立系统安全管理制度；未定期对运行日志和审计数据进行分析；
3) 恶意代码防范管理：未对系统进行恶意代码检测，并更新恶意代码库；未指定专人对网络和主机进行恶意代码检测；未安装防恶意代码软件。
4) 变更管理：未制定系统变更方案；
5) 应急预案管理：未制定电力二次系统联合防护和应急处置预案。

•

问题处置建议

网络安全

1、没有边界完整性检查

建议增加安全准入产品来增强接入网络设备的允许/阻断入网的管理。

2、没有入侵防范

建议增加网络控制设备，如 IDS 等，有效监测和阻断网络边界处以下攻击行为：端口扫描、强力攻击、木马后门攻击、拒绝服务攻击、缓冲区溢出攻击、IP 碎片攻击和网络蠕虫攻击等。

3、网络设备开启 telnet 功能

网络设备建议更换关闭 telnet 服务通过本地进行管理或采用加密的方式（如:SSH）进行远程管理。

4、网络设备管理权限未开启登陆地址限定

建议开启网络设备管理员权限用户固定 IP 或者固定 IP 段进行设备访问。

主机安全

1、口令强度策略不够完善。

建议强化操作系统的密码策略，加强用户口令长度与复杂度要求，并定期更换，如 30 天跟换，降低受到口令猜测、非授权访问的风险。

2、未启用登录失败处理功能。

建议开启失败登录处理功能，如限制非法登录次数、自动退出功能、锁定时间等，如限定非法登陆三次对登陆账户 IP 进行限时锁定，或者退出登陆界面。

3、服务器开启了不必要的端口。

服务器未遵循最小安装原则，安装多余的程序或组件，未及时升级更新服务器的补丁，开放了多余的端口（如 135、445）。上述端口是勒索病毒 Wanna Cry 的主要利用端口，不必要的端口可能存在被恶意用户利用的风险。

4、未安装防病毒软件

建议部署网络恶意代码防护产品和主机防病毒软件，并通过病毒监控中心对服务器病毒感染情况进行监控。定期更新防病毒软件特征库降低主机感染病毒、木马的风险。

5、操作系统未启用登录终端超时锁定功能。

系统未设置登录终端的超时锁定功能。如果用户登录操作系统后未退出或锁定而离开电脑，可能导致恶意用户非授权访问操作系统等。

应用安全

1、 未设置密码复杂度策略

建议在修改密码时采用才提示功能，和强行执行一定长度和复杂度密码的修改策略；

2、未启用审计功能；并形成审计记录

建议系统启用审计功能，审计记录的内容至少应包括事件的日期、时间、发起者信息、类型、描述和结果等；

3、系统没有对通信过程中的用户口令、会话密钥等敏感信息字段进行加密

建议系统存储和传输数据加密处理；

4、系统需要每隔 15 分钟查看信息，没有自动结束会话功能

系统随每隔 15 分钟进行一次数据查看，但如果长时间未操作没有自动结束会话功能，建议添加此功能完善系统安全性。

安全管理机构

1、 信息安全职能部门及负责人岗位设置不完善。

建议设立信息安全管理工作的职能部门，设立安全主管、安全管理各方面的负责人岗位，并定义各负责人的职责。

系统建设管理

1、外包软件开发没有做恶意代码检测

建议及时做外包软件恶意代码检测

2、也没有做外包软件源代码备份留存

建议向厂家追要外包软件源代码并进行本地备份。

系统运维管理

1、未制定信息系统安全管理制度

建议建立信息系统安全管理方面的管理制度，对安全策略、信息发布审核、日志管理和日常操作流程等作出明确规定。

2、未建立备份与恢复管理制度

建议建立备份与恢复管理相关的安全管理制度，对备份信息的备份方式、备份频度、存储介质和保存期等进行规范。

3、未建立网络安全管理制度

建议建立并完善建立网络安全管理制度，对网络安全配置、日志保存时间、安全策略、升级与打补丁、口令更新周期等方面作出规定。

4、未对网络设备进行漏洞扫描

建议定期（如每季度至少一次，可根据系统重要程度选择扫描频率）对网络系统进行漏洞扫描，对发现的网络系统安全漏洞进行及时的修补。

5、未对系统进行漏洞扫描

建议定期进行漏洞扫描，对发现的系统安全漏洞及时进行修补。

6、未制定应急预案

建议制定电力二次系统联合防护和应急处置预案，并应当定期进行演练。

7、未安装防恶意代码设备

建议安装防恶意代码设备。

目录

信息系统安全等级测评基本信息表.....3
声　　明.....4
等级测评结论.....5
总体评价.....4
主要安全问题.....7
问题处置建议.....9
目录.....12
1.1　测评目的.....1
1.2　测评依据.....1
1.3　测评过程.....3
1.4　报告分发范围.....5
2　被测信息系统情况.....6
2.1　承载的业务情况.....6
2.2　网络结构.....7
2.3　系统资产.....8
2.3.1　机房.....8
2.3.2　网络设备.....9
2.3.3　安全设备.....9
2.3.4　服务器/存储设备.....10
2.3.5　终端.....11
2.3.6　业务应用软件.....11
2.3.7　关键数据类别.....11
2.3.8　安全相关人员.....12
2.3.9　安全管理文档.....12
2.4　安全环境威胁评估.....14
2.5　前次测评情况.....15
3　等级测评范围与方法.....16
3.1　测评指标.....16
3.1.1　基本指标.....16
3.1.2　不适用指标.....20
3.1.3　特殊指标.....20
3.2　测评对象.....20
3.2.1　测评对象选择方法.....20
3.2.2　测评对象选择结果.....20
3.2.2.1　机房.....20
3.2.2.2　网络设备.....21
3.2.2.3　安全设备.....21
3.2.2.4　服务器/存储设备.....22
3.2.2.5　数据库管理系统.....22
3.2.2.6　业务应用软件.....22
3.2.2.7　终端.....22
3.2.2.8　访谈人员.....22
3.2.2.9　安全管理文档.....23

3.3 测评方法 25
4 单元测评 26
4.0 总体安全 26
4.0.1 结果分析 26
4.1 物理安全 26
4.1.1 结果汇总 26
4.1.2 结果分析 27
4.2 网络安全 27
4.2.1 结果汇总 27
4.2.2 结果分析 31
4.3 主机安全 32
4.3.1 结果汇总 32
4.3.2 结果分析 33
4.4 应用安全 34
4.4.1 结果汇总 34
4.4.2 结果分析 34
4.5 数据安全 35
4.5.1 结果汇总 35
4.5.2 结果分析 36
4.6 安全管理制度 36
4.6.1 结果汇总 36
4.6.2 结果分析 36
4.7 安全管理机构 37
4.7.1 结果汇总 37
4.7.2 结果分析 37
4.8 人员安全管理 37
4.8.1 结果汇总 37
4.8.2 结果分析 38
4.9 系统建设管理 38
4.9.1 结果汇总 38
4.9.2 结果分析 39
4.10 系统运维管理 39
4.10.1 结果汇总 39
4.10.2 结果分析 40
4.11 特殊指标 42
4.12 单元测评小结 42
4.12.1 控制点符合情况汇总 42
4.12.2 安全问题汇总 45
5 整体测评 53
5.1 安全控制间安全测评 53
5.2 层面间安全测评 53
5.3 区域间安全测评 54
5.4 验证测试 54
5.5 整体测评结果汇总 54
6 总体安全状况分析 56
6.1 系统安全保障评估 56
6.2 安全问题风险评估 59

6.3 等级测评结论 64
7 问题处置建议 66
7.1 网络安全 66
7.2 主机安全 66
7.3 安全管理机构 67
7.4 应用安全 67
7.5 系统建设管理 68
7.6 系统运维管理 68
附录A 等级测评结果记录 70
A.0 总体安全 70
A.1 物理安全 72
A.2 网络安全 74
A.2.1 网络全局 74
A.2.2 交换机 75
A.2.3 路由器 89
A.2.5 加密装置 99
A.2.6 反向隔离装置 南京博思特 Stone Wall-2000 106
A.2.7 网安监测装置 108
A.3 主机安全 112
A.3.1 光功率预测服务器 112
A.3.2 光功率气象服务器 120
A.3.3 气象服务器 123
A.4 应用安全 127
A.4.1 功率预测系统 127
A.4.2 光功率预测系统 129
A.5 数据安全 132
A.6 安全管理制度 133
A.7 安全管理机构 134
A.8 人员安全管理 137
A.9 系统建设管理 139
A.10 系统运维管理 144
A.11 特殊指标安全层面 155

1 测评项目概述

北京雅电信息安全科技有限公司（以下简称“北京雅电”）受定西市明晖新能源有限公司委托，依据《信息安全技术信息系统安全等级保护基本要求》、《信息安全技术信息系统安全等级保护测评要求》、《信息安全技术信息系统安全等级保护测评过程指南》，参考《信息安全技术信息系统安全通用技术要求》、《信息安全技术信息系统安全管理要求》等相关要求，于 2019 年 03 月 06 日开始对“光伏电站监控系统”进行信息系统安全等级保护测评（以下简称“等级测评”），至 2019 年 3 月 25 日完成了等级测评工作。

1.1 测评目的

通过等级测评工作的实施，既可以掌握信息系统的安全状况、排查系统安全隐患和薄弱环节、明确信息系统安全建设整改需求，也可以衡量信息系统的安全保护管理措施和技术措施是否符合等级保护基本要求，是否具备了相应的安全保护能力。

通过对“功率预测系统”的等级测评，旨在落实等级保护制度的各项要求， 全面提高信息系统安全防护能力，有效保障信息系统建设的健康发展。系统具有小规模、较弱强度恶意攻击的能力，抵御一般的自然灾害的能力，防范一般性计算机病毒和恶意代码危害的能力；具有检测常见的攻击行为，并对安全事件进行记录的能力；系统遭到损害后，具有恢复系统运行状态的能力。

1.2 测评依据

(1) 国家法律、法规文件

《中华人民共和国网络安全法》；

《中华人民共和国计算机信息系统安全保护条例》（国务院 147 号令）；

《国家信息化领导小组关于加强信息安全保障工作的意见》（中办发[2003]27

号）；

《信息安全等级保护管理办法》（公通字[2007]43 号）；

《关于开展全国重要信息系统安全等级保护定级工作的通知》（公信安[2007]861 号）；

《关于推动信息安全等级保护测评体系建设和开展等级测评工作的通知》（公信安[2010]303 号）；

(2) 国家标准

《计算机信息系统安全保护等级划分准则》（GB 17859-1999）；

《信息安全技术 信息系统安全等级保护基本要求》（GB/T 22239-2008）；

《信息安全技术 信息系统安全等级保护测评要求》（GB/T 28448-2012）；

《信息安全技术 信息安全等级保护实施指南》（GB/T 25058-2010）；

《信息安全技术 信息系统安全等级保护测评过程指南》（GB/T 28449-2012）；

《信息安全技术 信息系统通用安全技术要求》（GB/T 20271-2006）；

《信息安全技术 网络基础安全技术要求》（GB/T 20270-2006）；

《信息安全技术 操作系统安全技术要求》（GB/T 20272-2006）；

《信息安全技术 数据库管理系统安全技术要求》（GB/T 20273-2006）；

《信息安全技术 服务器技术要求》（GB/T 21028-2007）；

《信息安全技术 信息系统安全管理要求》（GB/T 20269-2006）；

(3) 电力行业标准

《关于开展电力行业信息系统安全等级保护定级工作的通知》（电监信息[2007]34 号）

《电力行业信息系统等级保护定级工作指导意见》（电监信息[2007]44 号）

《电力行业信息系统安全等级保护基本要求》（电监信息[2012]62 号）

《电力行业网络与信息安全管理办法》（国能安全[2014]317 号）

《电力行业信息安全等级保护管理办法》（国能安全[2014]318 号）

《电力监控系统安全防护规定》（发改委 14 号令）

《电力监控系统安全防护总体方案》及相关配套文件（国能安全[2015]36 号）

(4) 其它参考资料

信息系统安全等级保护备案材料；

信息系统安全等级测评合同；

1.3 测评过程

根据项目合同，项目周期 20 个日历日，自 2019 年 3 月 6 日起至 2019 年 3 月 25 日结束，项目实施过程大致分为测评准备、方案编制、现场测评、分析及报告编制四个阶段。

等级保护测评工作流程图如下图所示：

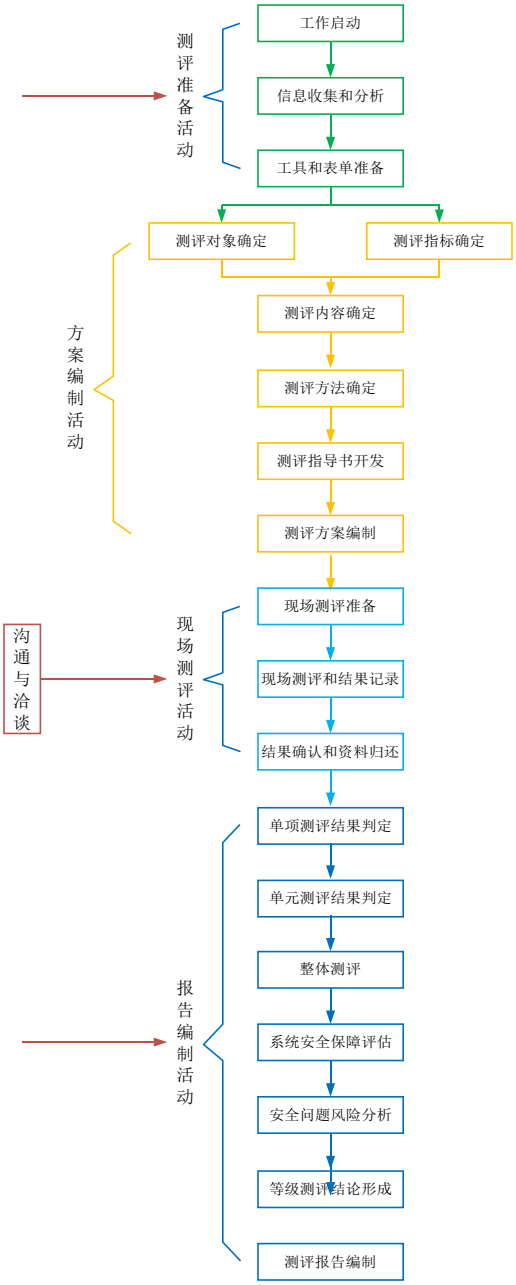


图 1-1 等级保护测评工作流程图

(1) 测评准备阶段

本阶段北京雅电与定西市明晖新能源有限公司组织招开了项目启动会，明确了此次工作的任务与计划，双方签署了项目的《保密协议》，北京雅电对“功率预测系统系统”进行了现场详细调研，掌握了被测系统的基本情况。

(2) 方案编制阶段

方案编制工作中，北京雅电主要对该系统测评对象与测评指标进行了确定与识

别，开发编制了符合本次项目的《测评指导书》与《测评方案》。方案编制工作的主要任务包括：测评对象确定、测评指标确定、测评内容确定、测评指导书开发及测评方案编制。

(3) 现场测评阶段

北京雅电首先与功率预测系统相关负责人就测评方案达成了一致意见，并进一步确定了测评配合人员，完成了测评指导书中各项测评工作内容，获取了足够的测评证据。现场测评活动的主要任务包括：现场测评准备、现场测评和结果记录、结果确认和资料归还。

(4) 分析与报告编制阶段

测评人员针对现场测评获得的测评证据和资料进行分析，分别对单项测评结果及单元测评结果进行判定，经过整体测评和风险分析，最终形成了《信息安全等级测评报告》。分析与报告编制工作的主要任务包括：单项测评结果判断、单元测评结果判定、整体测评、验证测试、系统安全保障评估、安全问题风险评估和等级测评结论形成及测评报告编制。

1.4 报告分发范围

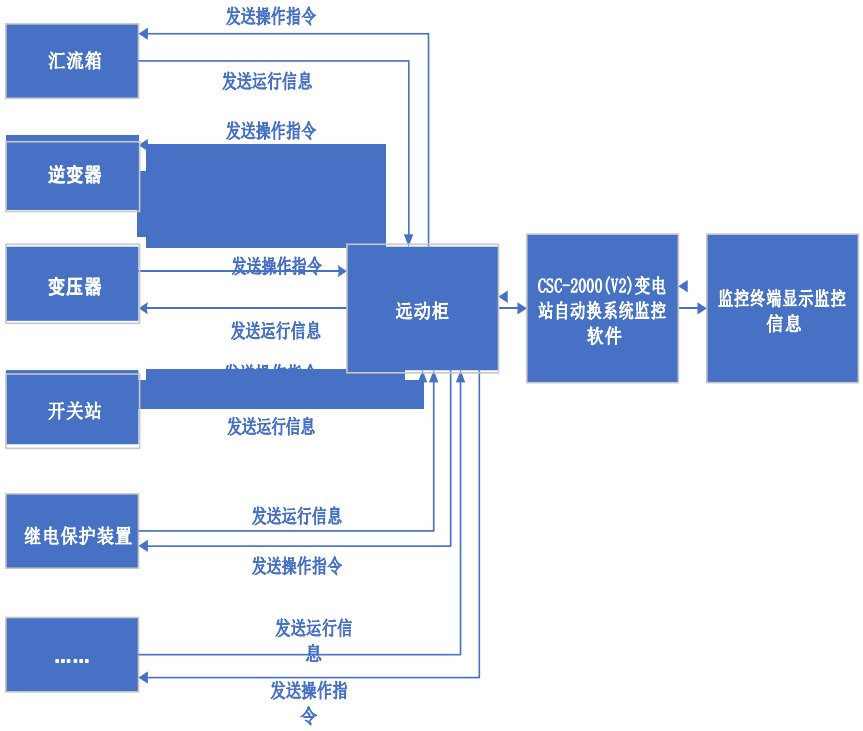
功率预测系统等级测评报告正本一式 4 份，其中定西市明晖新能源有限公司3份，北京雅电信息安全科技有限公司 1 份存档。

2 被测信息系统情况

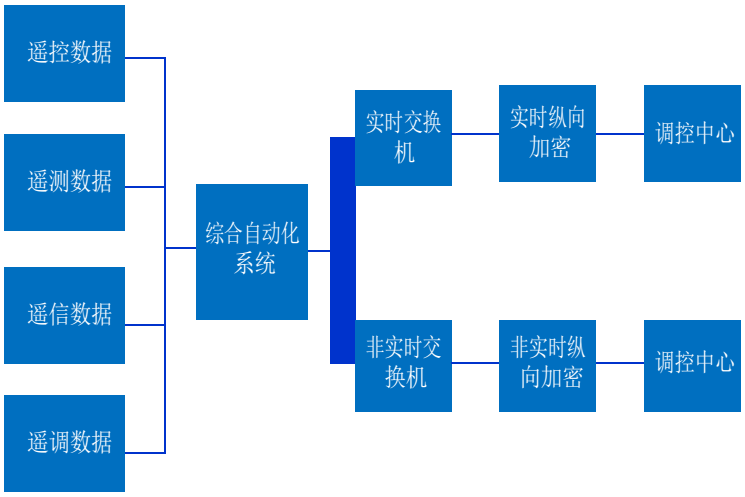
2.1 承载的业务情况

功率预测系统是按照电力行业等级保护及安全防护要求，由北京四方继保自动化股份有限公司设计、开发、以及销售和服务，电力监控系统安防部是该信息系统的责任部门。主要功能为实现光伏电站相关设备的数据采集、处理、监控、报警、报表等功能。

功率预测系统软件处理流程详见下图所示：



功率预测系统数据流程详见下图所示：



2.2 网络结构

定西市明晖新能源有限公司功率预测系统包含核心业务区、接入区和外联区；外联区包含外网防火墙；接入区包含内网交换机、内网防火墙、外网交换机、气象外网服务器、一平面路由器、二平面路由器、实时纵向加密、非实时纵向加密、实时交换机、非实时交换机、交换机；核心业务区包含网络安全监测装置和光功率预测接口服务器、光功率预测服务器；外联区和接入区由反向隔离装置物理隔离，接入区和核心业务区逻辑隔离；外联区边界由外网防火墙经光纤连接互联网，外网防火墙经外网交换机传输数据至气象外网服务器，核心业务区数据经交换机、纵向加密通过两个边界路由器经双 SDH 专线传输至省调和地调。

功率预测系统的网络结构图详见下图所示：

图 2-1 网络结构图

2.3 系统资产

系统资产包括被测信息系统相关的所有软硬件、人员、数据及文档等。

2.3.1 机房

以列表形式给出被测信息系统的部署机房。

表 2-1 系统资产-机房列表

序号	机房名称	物理位置
1	定西市明晖新能源有限公司 光伏发电站中控机房	甘肃省定西市安定区

2.3.2 网络设备

以列表形式给出被测信息系统中的网络设备。

表 2-2 系统资产-网络设备列表

序号	设备名称	操作系统	品牌	型号	用途	数量（台/套）	重要程度
1	一平面实时交换机	嵌入式操作系统	H3C	S3600V2 Series	一区数据交换	1	高
2	二平面实时交换机	嵌入式操作系统	H3C	S3600V2 Series	一区数据交换	1	高
3	二平面非实时交换机	嵌入式操作系统	H3C	S3600V2 Series	二区数据交换	1	高
4	控制区交换机	嵌入式操作系统	东土科技	SICOM3024P	系统前交换机	1	中
5	内网交换机	嵌入式操作系统	东土科技	SICOM3024P	互联网接入内网交换机	1	高
6	外网交换机	嵌入式操作系统	北京博维亚	WitNet_IAS3028A-24T-ADC220/S	互联网交换机	1	高
7	一平面路由器	嵌入式操作系统	H3C	MSR 36-40	连接省调	1	高
8	二平面路由器	嵌入式操作系统	H3C	MSR 50-40	连接地调	1	高

2.3.3 安全设备

以列表形式给出被测信息系统中的安全设备。

表 2-3 系统资产-安全设备列表

序号	设备名称	操作系统	品牌	型号	用途	数量（台/套）	重要程度
1	内网防火墙	嵌入式操作系统	华为	Secoway USG2000	生产 I 区和生产 II 区边界隔离	1	高
2	外网防火墙	嵌入式操作系统	华为	Secoway USG2000	互联网边界隔离	1	高
3	光功率预测防火墙	嵌入式操作系统	华为	Secoway USG2000	生产 II 区与外联区隔离	1	高

序号	设备名称	操作系统	品牌	型号	用途	数量（台/套）	重要程度
4	一平面实时纵向加密装置	嵌入式操作系统	兴唐	SJW07-A	对上传、接收地调信息进行加密	1	高
5	二平面实时纵向加密装置	嵌入式操作系统	兴唐	SJW07-A	对上传、接收省调信息进行加密	1	高
6	二平面非实时纵向加密装置	嵌入式操作系统	兴唐	SJW07-A	对上传、接收省调信息进行加密	1	高
7	光功率预测网络安全反向隔离装置	嵌入式操作系统	北京科东	Stone Wall-2000	单向从互联网传入内网	1	高
8	控制区网络安全监测装置	嵌入式操作系统	北京科东	PSSEM-2000S	监测设备运行状态及审计	1	高
9	非控制区网络安全监测装置	嵌入式操作系统	北京科东	PSSEM-2000S	监测设备运行状态及审计	1	高

2.3.4 服务器/存储设备

以列表形式给出被测信息系统中的服务器和存储设备，描述服务器和存储设备的项目包括设备名称、操作系统、数据库管理系统以及承载的业务应用软件系统。

表 2-4 系统资产-服务器/存储设备列表

序号	设备名称	操作系统/数据库管理系统	版本	业务应用软件	数量（台/套）	重要程度
1	气象服务器	Linux	Centos 6	气象管理端	1	高
2	光功率预测服务器	Linux	Redhat 6.7	监控系统	2	高
3	光功率预测监控服务器	Windows	Windows7	光功率终端	1	高

2.3.5 终端

以列表形式给出被测信息系统中的终端，包括业务管理终端、业务终端和运维终端等。

表 2-5 系统资产-终端列表

无

2.3.6 业务应用软件

以列表的形式给出被测信息系统中的业务应用软件（包括含中间件等应用平台软件），描述项目包括软件名称、主要功能简介。

表 2-6 系统资产-业务应用软件列表

序号	软件名称	主要功能	开发厂商	重要程度
1	国能日新光功率预测系统软件	气象信息、预测功率信息	国能日新科技股份有限公司	高

2.3.7 关键数据类别

以列表形式描述具有相近业务属性和安全需求的数据集合。

表 2-7 系统资产-关键数据类别

序号	数据类别	所属业务应用	安全防护需求	重要程度
1	电力生产功率预测数据	光功率预测系统软件	中	一般

2.3.8 安全相关人员

以列表形式给出与被测信息系统安全相关的人员情况。相关人员包括（但不限于）安全主管、系统建设负责人、系统运维负责人、网络（安全）管理员、主机（安全）管理员、数据库（安全）管理员、应用（安全）管理员、机房管理人员、资产管理员、业务操作员、安全审计人员等。

表 2-8 系统资产-安全相关人员列表

序号	姓名	岗位/角色	联系方式
1	靳海	安全主管	18693515240
2	靳海	安全管理员/系统管理员/资产管理员/系统运维负责人	18693515240
3	靳海	物理安全负责人/办公环境管理员/设备管理员	18693515240
4	靳海	系统建设负责人	18693515240
5	靳海	人事工作人员	18693515240

2.3.9 安全管理文档

以列表形式给出与信息系统安全相关的文档，包括管理类文档、记录类文档和其他文档。

表 2-9 系统资产-安全管理文档列表

序号	文档名称	主要内容
1	定西电力调度系统网络安全责任书	规定了机构总体安全方针和政策方面的管理制度
2	电力监控系统安全防护管理制度	电力监控系统安全主管负责整体安全防护，重大事件有上报审批流程。
3	电力监控系统安全防护岗位职责	明确了网络管理员、系统管理员、安全管理员等的职责，说明了系统维护的授权审批流程
4	光功率预报管理系统系统管理员使用手册	为维护光功率预测系统的管理员提供指导，使之能够快速的管理和使用光功率预测系统。
5	光功率预报管理系统使用手册	为使用光功率预测系统的工作人员提供指导和说明。

序号	文档名称	主要内容
6	人事管理制度	规定了人员录用的要求和流程、人员离岗需要收回的权限和物品、人员考核的方式等。
7	年度信息安全培训计划	规定了每年要对所有人员进行信息安全意识教育培训，提升所有人员的信息安全意识。
8	继电保护室人员出入登记表	第三方人员进入机房需要经过审批流程并在机房出入登记表做记录，进入机房由专人陪同并处于视频监控区域。
9	项目实施管理制度	工程实施由专人负责监督进度和质量，每次工程实施都有实施方案控制工程实施过程。
10	产品采购管理制度	产品选型、采购都由专人负责，并且需要符合国家和行业相关规定。
11	电力监控系统设备台账（工作站）	包含工作站的具体信息，设备型号、厂家、采购和使用时间等。
12	电力监控系统设备台账（光功率预测屏）	包含光功率预测屏的厂家、型号、采购和使用时间、技术支持人员联系方式等。
13	电力监控系统设备台账（调度数据柜）	包含调度数据柜的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
14	电力监控系统设备台账（功率优化控制屏）	包含功率优化控制屏的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
15	电力监控系统设备台账（光纤通讯柜）	包含光纤通讯柜的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
16	电力监控系统设备台账（远动通讯屏）	包含远动通讯屏的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
17	应用系统服务器排查台账	应用系统服务器排查的时间、当时的运行状态。
18	电力监控系统运维管理规定	电力监控系统运维由专人负责，厂家长期提供技术支持。
19	病毒防范方面的管理制度	所有外接设备都需要确保已经过杀毒处理，防止病毒的感染对系统造成严重影响。
20	系统变更控制方面的管理制度	系统变更需要经过总经理审批并有详细的变

序号	文档名称	主要内容
		更方案。
21	密码管理方面的管理制度	所有密码至少使用 8 位以上字母加数字的形式，三个月定期修改，密码要妥善保存防止泄露。
22	安全事件和应急响应预案	规定安全事件上报和审批流程，全员定期做应急响应预案培训。
23	其他文档	其他文档

2.4 安全环境威胁评估

描述被测信息系统的运行环境中与安全相关的部分，并以列表形式给出被测信息系统的威胁列表。

表 2-10 安全环境威胁评估列表

序号	威胁分(子)类	描述	威胁赋值
T1	软硬件故障	对业务实施或系统运行产生影响的设备硬件故障、通信链路中断、系统本身或软件缺陷等问题	中
T2	物理环境影响	对信息系统正常运行造成影响的物理环境问题和自然灾害	低
T3	无作为或操作失误	应执行而没有执行相应的操作	低
T4	管理不到位	安全管理无法落实或不到位，从而破坏信息系统正常有序运行	低
T5	恶意代码	在计算机系统上执行恶意任务的程序	中
T6	越权或滥用	通过采用一些措施，超越自己的权限访问本来无权访问的资源，或者滥用自己的权限，作出破坏信息的行为	低
T7	网络攻击	利用工具和技术通过网络对信息系统入侵	中
T8	物理攻击	通过物理的接触造成对软件、硬件、数据的破坏	低
T9	泄密	信息泄露给不应解的他人	低
T10	篡改	非法修改信息、破坏的完整性使信息系统的安全性降低或信息不可用	低
T11	抵赖	不承认收到的信息和所做的操作或交易	低

2.5 前次测评情况

功率预测系统本次为首次测评。

3 等级测评范围与方法

3.1 测评指标

测评指标包括基本指标和特殊指标两部分。

3.1.1 基本指标

《基本要求》中对不同等级信息系统的安全功能和措施提出了具体要求，等级测评应根据信息系统的安全保护等级从中选取相应等级的安全测评指标，并依据《测评要求》和《测评过程指南》对信息系统实施安全测评。

本次安全等级测评范围内的测试系统的安全保护等级为第二级，其中业务信息安全保护等级为第二级，系统服务安全保护等级为第二级(S2A2G2)。

表 3-1 基本指标-统计列表

安全要求类	层 面	控制点数量			小计	要求项数量			小计
		S	A	G		S	A	G	
安全技术	物理安全	1	1	8	10	1	2	16	19
	网络安全	1	0	5	6	1	0	20	21
	主机安全	2	1	3	6	9	4	7	20
	应用安全	4	2	1	7	11	5	3	19
	数据安全及备份恢复	2	1	0	3	2	2	0	4
安全管理	安全管理制度	0	0	3	3	0	0	7	7
	安全管理机构	0	0	6	6	0	0	12	12
	人员安全管理	0	0	5	5	0	0	11	11
	系统建设管理	0	0	9	9	0	0	31	31
	系统运维管理	0	0	12	12	0	0	47	47
合 计		10	5	52	67	24	13	154	191

表 3-2 基本指标--详细列表

安全层面	安全控制点	测评项数

安全层面	安全控制点	测评项数
物理安全	物理位置的选择（G）	1
	物理访问控制（G）	2
	防盗窃和防破坏（G）	5
	防雷击（G）	2
	防火（G）	1
	防水和防潮（G）	3
	防静电（G）	1
	温湿度控制（G）	1
	电力供应（A）	2
	电磁防护（S）	1
网络安全	结构安全（G）	4
	访问控制（G）	6
	安全审计（G）	2
	边界完整性检查（S）	1
	入侵防范（G）	1
	恶意代码防范（G）	—
	网络设备防护（G）	7
主机安全	身份鉴别（S）	5
	访问控制（S）	4
	安全审计（G）	4
	剩余信息保护（S）	—
	入侵防范（G）	1
	恶意代码防范（G）	2
	资源控制（A）	4
应用安全	身份鉴别（S）	4
	访问控制（S）	4

安全层面	安全控制点	测评项数
	安全审计（G）	3
	剩余信息保护（S）	—
	通信完整性（S）	1
	通信保密性（S）	2
	抗抵赖（G）	—
	软件容错（A）	2
	资源控制（A）	3
数据安全	数据完整性（S）	1
	数据保密性（S）	1
	数据备份与恢复（A）	2
安全管理制度	管理制度（G）	3
	制定和发布（G）	3
	评审和修订（G）	1
安全管理机构	岗位设置（G）	3
	人员配备（G）	2
	资金保障（G）	1
	授权和审批（G）	3
	沟通和合作（G）	2
	审核和检查（G）	1
人员安全管理	人员录用（G）	3
	人员离岗（G）	3
	人员考核（G）	1
	安全意识教育和培训（G）	3
	外部人员访问管理（G）	1
系统建设管理	系统定级（G）	4
	安全方案设计（G）	4

安全层面	安全控制点	测评项数
	产品采购（G）	4
	自行软件开发（G）	3
	外包软件开发（G）	5
	工程实施（G）	2
	测试验收（G）	3
	系统交付（G）	3
	系统备案（G）	—
	等级测评（G）	—
	安全服务商选择（G）	3
系统运维管理	环境管理（G）	4
	资产管理（G）	2
	介质管理（G）	5
	设备管理（G）	5
	监控管理和安全管理中心（G）	—
	网络安全管理（G）	6
	系统安全管理（G）	7
	恶意代码防范管理（G）	4
	密码管理（G）	1
	变更管理（G）	2
	备份与恢复管理（G）	3
	安全事件处置（G）	5
	应急预案管理（G）	3
总计		**191**

3.1.2 不适用指标

该监控系统的不适用指标详见下表所示：

表 3-3 不适用指标

安全层面	安全控制点	不适用项	原因说明
系统建设管理	自行软件开发	a) 应确保开发环境与实际运行环境物理分开；	无自行软件开发。
		b) 应制定软件开发管理制度，明确说明开发过程的控制方法和人员行为准则；	
		c) 应确保提供软件设计的相关文档和使用指南，并由专人负责保管。	

3.1.3 特殊指标

该监控系统无特殊指标。

3.2 测评对象

3.2.1 测评对象选择方法

依据《GB/T 28449-2012 信息系统安全等级保护测评过程指南》的测评对象确定原则和方法，结合资产重要程度赋值结果，描述本报告中测评对象的选择规则和方法。

3.2.2 测评对象选择结果

3.2.2.1 机房

表 3-4 测评对象-机房列表

序号	机房名称	物理位置	重要程度
1	光伏发电站中控机房	甘肃省定西市武山县河程村	高

3.2.2.2 网络设备

表 3-5 测评对象-网络设备列表

序号	设备名称	操作系统	用途	重要程度
1	一平面实时交换机	嵌入式操作系统	一平面数据交换	高
2	二平面实时交换机	嵌入式操作系统	二平面数据交换	高
3	二平面非实时交换机	嵌入式操作系统	二平面数据交换	高
4	控制区交换机	嵌入式操作系统	控制区交换机	中
5	内网交换机	嵌入式操作系统	互联网接入内网交换机	高
6	外网交换机	嵌入式操作系统	互联网交换机	中
7	一平面路由器	嵌入式操作系统	连接地调	高
8	二平面路由器	嵌入式操作系统	连接省调	高

3.2.2.3 安全设备

表 3-6 测评对象-安全设备列表

序号	设备名称	操作系统	用途	重要程度
1	外网防火墙	嵌入式操作系统	边界防火墙	高
2	内网防火墙	嵌入式操作系统	生产I 区和生产 II 区防火墙	高
3	一平面实时纵向加密装置	嵌入式操作系统	对上传、接收地调信息进行加密	高
4	二平面实时纵向加密装置	嵌入式操作系统	对上传、接收地调信息进行加密	高
5	二平面非实时纵向加密装置	嵌入式操作系统	对上传、接收省调信息进行加密	高
6	光功率预测网络安全反向隔离装置	嵌入式操作系统	单向从互联网传入内网	高
7	控制区网络安全监测装置	嵌入式操作系统	监测设备运行状态及审计	高
8	非控制区网络安全监测装置	嵌入式操作系统	监测设备运行状态及审计	高

3.2.2.4 服务器/存储设备

表 3-7 测评对象-服务器/存储设备列表

序号	设备名称	操作系统 /数据库管理系统	业务应用软件	重要程度
1	监控服务器	Centos 6.0	气象管理端	高
2	光功率预测服务器	Redhat 6.7	光功率终端	中
3	光功率气象服务器	Windows 7	光功率终端	中

3.2.2.5 数据库管理系统

表 3-8 测评对象-数据库管理系统列表

序号	数据库系统名称	数据库管理系统类型	所在设备名称	重要程度
—	—	—	—	—

3.2.2.6 业务应用软件

表 3-9 测评对象-业务应用软件列表

序号	软件名称	主要功能	开发厂商	重要程度
1	国能日新光功率预测系统软件	气象信息、预测功率信息	国能日新科技股份有限公司	高

3.2.2.7 终端

表 3-10 测评对象-终端列表

序号	设备名称	操作系统	用途	重要程度
1	气象服务器终端	Red Hat 6.0	监测终端	中

3.2.2.8 访谈人员

表 3-11 测评对象-访谈人员列表

序号	姓名	岗位/职责
1	王明波	安全主管
2	夏源	安全管理员/系统管理员/资产管理员/系统运维负责人
3	梁义臣	物理安全负责人/办公环境管理员/设备管理员
4	马国峰	系统建设负责人
5	伍淦彬	人事工作人员

3.2.2.9 安全管理文档

表 3-12 测评对象-安全管理文档列表

序号	文档名称	主要内容
1	定西电力调度系统网络安全责任书	规定了机构总体安全方针和政策方面的管理制度
2	电力监控系统安全防护管理制度	电力监控系统安全主管负责整体安全防护，重大事件有上报审批流程。
3	电力监控系统安全防护岗位职责	明确了网络管理员、系统管理员、安全管理员等的职责，说明了系统维护的授权审批流程
4	光功率预报管理系统系统管理员使用手册	为维护光功率预测系统的管理员提供指导，使之能够快速的管理和使用光功率预测系统。
5	光功率预报管理系统使用手册	为使用光功率预测系统的工作人员提供指导和说明。
6	人事管理制度	规定了人员录用的要求和流程、人员离岗需要收回的权限和物品、人员考核的方式等。
7	年度信息安全培训计划	规定了每年要对所有人员进行信息安全意识教育培训，提升所有人员的信息安全意识。
8	继电保护室人员出入登记表	第三方人员进入机房需要经过审批流程并在机房出入登记表做记录，进入机房由专人陪同并处于视频监控区域。

序号	文档名称	主要内容
9	项目实施管理制度	工程实施由专人负责监督进度和质量，每次工程实施都有实施方案控制工程实施过程。
10	产品采购管理制度	产品选型、采购都由专人负责，并且需要符合国家和行业相关规定。
11	电力监控系统设备台账（工作站）	包含工作站的具体信息，设备型号、厂家、采购和使用时间等。
12	电力监控系统设备台账（光功率预测屏）	包含光功率预测屏的厂家、型号、采购和使用时间、技术支持人员联系方式等。
13	电力监控系统设备台账（调度数据柜）	包含调度数据柜的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
14	电力监控系统设备台账（功率优化控制屏）	包含功率优化控制屏的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
15	电力监控系统设备台账（光纤通讯柜）	包含光纤通讯柜的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
16	电力监控系统设备台账（远动通讯屏）	包含远动通讯屏的厂家、型号、采购和使用时间、技术支持人员联系方式等具体信息。
17	应用系统服务器排查台账	应用系统服务器排查的时间、当时的运行状态。
18	电力监控系统运维管理规定	电力监控系统运维由专人负责，厂家长期提供技术支持。
19	病毒防范方面的管理制度	所有外接设备都需要确保已经过杀毒处理，防止病毒的感染对系统造成严重影响。
20	系统变更控制方面的管理制度	系统变更需要经过总经理审批并有详细的变更方案。
21	密码管理方面的管理制度	所有密码至少使用 8 位以上字母加数字的形式，三个月定期修改，密码要妥善保存防止泄露。

序号	文档名称	主要内容
22	安全事件和应急响应预案	规定安全事件上报和审批流程，全员定期做应急响应预案培训。
23	其他文档	其他文档

3.3 测评方法

等级测评现场实施期间，测试项目组成员分别采用访谈、检查、测试和风险分析的方法对被测评系统进行测评，测评内容覆盖《基本要求》中第二级安全保护能力各个层面的要素。

访谈是指测评人员通过引导信息系统相关人员进行有目的的（有针对性）交流以帮助测评人员理解或取得证据的过程。访谈主要应用于安全管理测评中，并以此来获取证据；在安全技术测评方面，访谈主要用于收集目标系统的信息以辅助后续的检查或者测试。其工作对象为信息系统相关的使用、管理和维护人员。

检查是指测评人员通过测评对象（如制度、各类设备、安全配置等）进行观察、查验、分析以帮助测评人员理解或取得证据的过程。检查方法和应用范围覆盖了物理安全测评、主机安全测评、网络安全测评、应用安全测评和数据安全及备份恢复等方面的安全技术测评，以及安全管理机构、人员安全管理测评、安全管理制度测评、系统建设管理测评和系统运维管理等方面的安全管理测评。其工作对象为文档、机制、设备等。

测试是指测评人员使用预定的防范/工具使测评对象（各类设备或安全配置） 产生特定的结果，将运行结果与预期的结果进行比对的过程，主要包括手工验证、漏洞扫描、渗透测试等测试操作。测试结果用于判断目标系统在网络、主机或应用层面采用的特定技术措施是否符合国家相关标准以及委托方的实际需求，并进一步对目标系统进行安全性整体分析。其工作对象为机制、设备等。

4 单元测评

单元测评内容包括“3.1.1 基本指标”以及“3.1.3 特殊指标”中涉及的安全层面，内容由问题分析和结果汇总等两个部分构成，详细结果记录及符合程度参见报告附录A。

4.0 总体安全

4.0.1 结果分析

通过现场检查，德佑电站生产大区和管理信息大区，时实区和非实时区划分明显，不存在混插现象，各区域间存在有效隔离设备；理信息大区与生产控制大区之间有反向隔离装置；生产控制大区与广域网之间的纵向加密装置策略有效执行，存在加密日志；电力调度数据出口处为电力专用 VPN 通道，物理层面调离调度数据网与外部公共信息网络物理隔离。不存在调度数据网接入互联网情况；不存在应为一区的信息系统网络接入二区网络的情况，不存在应为二区的信息系统网络接入一区网络的情况；控制区与非控制区之间存在 H3C 防火墙设备；该电站所有信息系统均为二级系统，不用独立成域；生产控制大全部署网络安全检测装置，装置接入监控系统，光功率预测，南瑞有工，隔离装置，纵向加密装置，交换机，防火墙等。查看日志记录，可以对这些设备的日志进行收集，并有日志的类型，描述，时间等关键信息。

4.1 物理安全

4.1.1 结果汇总

针对不同安全控制点对单个测评对象在物理安全层面的单项测评结果进行汇总和统计。

表 4-1 物理安全-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点									
			物理位置的选择	物理访问控制	防盗窃和防破坏	防雷击	防火	防水和防潮	防静电	温湿度控制	电力供应	电磁屏蔽
1	光伏发电站中控机房	符合	1	2	5	2	1	3	1	1	2	1
		部分符合	0	0	0	0	0	0	0	0	0	0
		不符合	0	0	0	0	0	0	0	0	0	0
		不适用	0	0	0	0	0	0	0	0	0	0

4.1.2 结果分析

安全保护措施：

中控室机房建立在升压站一楼，房屋为混凝土建筑，外设有避雷针、防护围栏，具有有效的防震、防风、防雨能力；机房内 24 小时有专人值守，来访人员有进出记录，并有专人全程陪同和监督其活动范围；主要设备放置于房屋内中控室内的机房中，设备安装在机柜内进行固定，并有明显不易去除的设备标记，通信电缆全部铺设于地下，介质分类标记存放于档案柜内，中控室内安装有监控和报警装置；建筑四周和楼顶设有避雷针装置，各个门口设置接地装置；机房有火灾自动报警装置；无给排水管道，屋顶、窗户已做防渗透措施，无渗水霜露凝结痕迹；设备配备防静电手环，并有接地线路；空调可保障机房温湿度；配备 UPS 作为短期备用电源设备，可满足 2 小时的供电需求；通信线路和电源线隔离铺设，不相互干扰。

4.2 网络安全

4.2.1 结果汇总

针对不同安全控制点对单个测评对象在网络安全层面的单项测评结果进行汇总和统计。

表 4-2 网络安全-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点						
			结构安全	访问控制	安全审计	边界完整性检查	入侵防范	恶意代码防范	网络设备防护
1	网络全局	符合	4	-	-	0	0	-	-
		部分符合	0	-	-	1	0	-	-
		不符合	0	-	-	0	1	-	-
		不适用	0	-	-	0	0	-	-
2	一平面实时交换机	符合	-	5	2	-	-	-	4
		部分符合	-	0	0	-	-	-	2
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
3	二平面实时交换机	符合	-	5	2	-	-	-	4
		部分符合	-	0	0	-	-	-	2
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
4	二平面非实时交换机	符合	-	5	2	-	-	-	4
		部分符合	-	0	0	-	-	-	2
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
5	控制区交换机	符合	-	5	2	-	-	-	4
		部分符合	-	0	0	-	-	-	2
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0

序号	测评对象	符合情况	安全控制点						
			结构安全	访问控制	安全审计	边界完整性检查	入侵防范	恶意代码防范	网络设备防护
6	内网交换机	符合	-	5	2	-	-	-	4
		部分符合	-	0	0	-	-	-	2
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
7	外网交换机	符合	-	5	2	-	-	-	5
		部分符合	-	0	0	-	-	-	1
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
8	一平面路由器	符合	-	5	2	-	-	-	4
		部分符合	-	0	0	-	-	-	2
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
9	二平面路由器	符合	-	5	2	-	-	-	4
		部分符合	-	0	0	-	-	-	2
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
10	外网防火墙	符合	-	6	2	-	-	-	6
		部分符合	-	0	0	-	-	-	1
		不符合	-	0	0	-	-	-	0
		不适用	-	0	0	-	-	-	0
11	内网防火墙	符合	-	6	2	-	-	-	6

序号	测评对象	符合情况	安全控制点						
			结构安全	访问控制	安全审计	边界完整性检查	入侵防范	恶意代码防范	网络设备防护
		部分符合	-	0	0	-	-	-	1
		不符合	-	0	0	-	-	-	0
		不适用	-	0	0	-	-	-	0
12	一平面省调实时纵向加密	符合	-	5	2	-	-	-	5
		部分符合	-	0	0	-	-	-	1
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
13	一平面地调实时纵向加密	符合	-	2	2	-	-	-	5
		部分符合	-	5	2	-	-	-	1
		不符合	-	0	0	-	-	-	1
		不适用	-	0	0	-	-	-	0
14	二平面非实时纵向加密	符合	-	5	2	-	-	-	5
		部分符合	-	0	0	-	-	-	1
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
15	反向隔离装置	符合	-	5	0	-	-	-	4
		部分符合	-	0	0	-	-	-	1
		不符合	-	0	2	-	-	-	1
		不适用	-	1	0	-	-	-	0
16	控制区网安监测装置珠海鸿瑞	符合	-	5	2	-	-	-	5
		部分符合	-	0	0	-	-	-	1

序号	测评对象	符合情况	安全控制点						
			结构安全	访问控制	安全审计	边界完整性检查	入侵防范	恶意代码防范	网络设备防护
	HR CRPM-3000	不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0
17	非控制区网安监测装置珠海鸿瑞HR CRPM-3000	符合	-	5	2	-	-	-	5
		部分符合	-	0	0	-	-	-	1
		不符合	-	0	0	-	-	-	1
		不适用	-	1	0	-	-	-	0

4.2.2 结果分析

安全保护措施：

网络中核心设备 H3C 系列设备具有多业务并发处理能力，电口的配置保证业务高峰期需求；网络拓扑标注设备 IP 地址并与实际情况相符合；各区域根据电力调度要求划分 vlan 并配置 IP 地址；电力调度数据网边界处设有网络安全监测装置可监测接入设备、安全事件及设备异常等信息，采用 IP-MAC 地址绑定方式防止未授权设备接入网络；互联网与电力调度数据网边界处设有防火墙；电力调度数据网生厂区与信息管理大区边界设置防火墙；

安全问题：

1 边界处部署网络安全监测装置，可发现私自连接内部网络的行为，但对其行为没有任何操作。建议增加入网准入设备，控制网络入口。

2 网络边界处没有入侵防范等任何安全设备。建议增加 IDS 等边界安全防护设备，可抵抗网络入侵。

3　默认开启 telnet 功能，建议关闭此功能进行安全防护。（一平面实时交换机、二平面实时交换机、二平面非实时交换机、控制区交换机、内网交换机、一平面路由器、二平面路由器）。

4　网络设备设置管理员用户，但未对登录地址进行限制。（一平面实时交换机、二平面实时交换机、二平面非实时交换机、控制区交换机、内网交换机、外网交换机、一平面路由器、二平面路由器、一平面省调实时纵向加密、一平面地调实时纵向加密、二平面非实时纵向加密、反向隔离装置、控制区网安监测装置、非控制区网安监测装置）

5　全部网络设备口令不定期进行更换，没有定期进行更换。

6　没有启用安全审计功能，审计记录应包括事件的日期和时间、用户、事件类型等。（反向隔离装置）

4.3 主机安全

4.3.1 结果汇总

针对不同安全控制点对单个测评对象在主机安全层面的单项测评结果进行汇总和统计。

表 4-3 主机安全-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点					
			身份鉴别	访问控制	安全审计	入侵防范	恶意代码防范	资源控制
1	光功率预测服务器	符合	4	3	4	1	0	3
		部分符合	1	0	0	0	0	0

序号	测评对象	符合情况	安全控制点					
			身份鉴别	访问控制	安全审计	入侵防范	恶意代码防范	资源控制
		不符合	0	0	0	0	1	1
		不适用	0	0	0	0	1	0
2	光功率气象服务器	符合	4	3	4	0	0	3
		部分符合	1	0	0	1	0	0
		不符合	0	0	0	0	1	1
		不适用	0	0	0	0	1	0
3	气象服务器终端	符合	3	3	4	0	0	3
		部分符合	2	0	0	1	0	0
		不符合	0	0	0	0	1	1
		不适用	0	0	0	0	1	0

4.3.2 结果分析

安全保护措施：

在主机安全方面，操作系统启用了对管理用户的身份鉴别功能，通过“用户名+口令”的方式进行鉴别，系统资源满足当前业务使用需求。管理员设置的操作系统口令长度大于 8 位，至少包含字母、数字和特殊字符组成。

安全问题：

1、管理员设置了长度大于 8 位，至少包含字母、数字和特殊字符组成的口令，但操作系统采用默认口令策略。

2、气象服务器终端采用默认的帐户锁定策略。

3、气象服务器终端操作系统未遵循最小安装原则，关闭了操作系统的升级更新， 开启了多余的端口（如：135、445 等）。

4、操作系统未安装防病毒软件。

5、未设置操作超时锁定。

4.4 应用安全

4.4.1 结果汇总

表 4-4 应用安全-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点								
			身份鉴别	访问控制	安全审计	剩余信息保护	通信完整性	通信保密性	抗抵赖	软件容错	资源控制
1	功率预测系统	符合	4	4	0	0	1	0	0	1	0
		部分符合	1	0	0	0	0	0	0	0	0
		不符合	0	0	1	0	0	2	0	1	3
		不适用	0	0	2	0	0	0	0	0	0
2	光功率预测系统	符合	4	4	0	0	1	0	0	1	0
		部分符合	1	0	0	0	0	0	0	0	0
		不符合	0	0	1	0	0	2	0	1	3
		不适用	0	0	2	0	0	0	0	0	0

4.4.2 结果分析

安全保护措施：

功率预测系统提供专用登录控制模块，对登录用户进行“用户名+口令” 身份标识及鉴别；用户口令采用 8 位以上大小写字母加数字形式且定期更换；不同访问账户分配了不同访问权限；纵向加密设备保证通信的保密性；系统采用双通道传输数据，确保系统发生故障时自动保护当前状态。

安全问题：

（1） 采取用户名+密码的方式进行登录，对用户身份进行鉴别，修改密码未设置密码复杂度策略；

（2） 系统没有审计功能，审计内容覆盖到每个用户的安全审计功能，对应用系统的用户登录、用户退出、增加用户、修改用户权限等重要安全事件进行审计；

（3） 系统为 C/S 架构，固定 IP 地址/端口进行通信，没有利用密码技术进行会话初始化验证；

（4） 系统没有对通信过程中的用户口令、会话密钥等敏感信息字段进行加密；

（5） 系统未提供数据有效性检验功能，如固定字段传输、字段长度等；

（6） 系统需要每隔 15 分钟查看信息，没有自动结束会话功能；

（7） 系统没有对系统的最大并发会话连接数进行限制；

（8） 系统业务峰值为单用户操作。没有对单个帐户的多重并发会话进行限制。

4.5 数据安全

4.5.1 结果汇总

表 4-5 数据安全-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点		
			数据完整性	数据保密性	备份和恢复
1	数据安全及备份恢复	符合	1	1	2
		部分符合	0	0	0
		不符合	0	0	0
		不适用	0	0	0

4.5.2 结果分析

在数据保护方面，对关键数分别采取 VPN 通道上传数据，保证完整性保护和加密措施，重要业务数据进行备份。

4.6 安全管理制度

4.6.1 结果汇总

表 4-6 安全管理制度-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点		
			管理制度	制定和发布	评审和修订
1	安全管理制度	符合	3	2	0
		部分符合	0	1	1
		不符合	0	0	0
		不适用	0	0	0

4.6.2 结果分析

安全保护措施：

安全管理制度方面提供工作的总体方针和安全策略，提供所管辖范围内计算机及数据网络的安全管理；建立安全管理制度，包括：门禁管理、人员管理、权限管理、访问控制管理、安全防护系统的维护管理、常规设备及各系统的维护管理、恶意代码的防护管理、审计管理、数据及系统的备份管理、用户口令密钥及数字证书的管理、培训管理等；制定对应安全管理人员的操作管理规程；制定和发布人员安全管理制度；管理制度通过专人进行论证；制度通过正式文件的方式下发至员工手中；定期对制度不合理处进行修正，发生重大变更对管理制度进行检查和审定。

4.7 安全管理机构

4.7.1 结果汇总

表 4-7 安全管理机构-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点					
			岗位设置	人员配备	资金保障	授权和审批	沟通和合作	审核和检查
1	安全管理员	符合	3	2	2	3	2	0
		部分符合	0	0	0	0	0	1
		不符合	0	1	0	0	0	0
		不适用	0	0	0	0	0	0

4.7.2 结果分析

安全保护措施：

建立安全管理机构，由安防部总经理作为安全管理机构负责人，建立安全主管、系统管理员、网络管理员、安全管理员等岗位并明确相关职责。明确安全管理机构各部门职责，建立完善的制度审批流程。

安全问题：

1. 在人员配置方面，未设置专职的安全管理员。

4.8 人员安全管理

4.8.1 结果汇总

表 4-8 人员安全管理-单元测评结果汇总表

序	测评对象	符合情况	安全控制点

号			人员录用	人员离岗	人员考核	安全意识教育和培训	外部人员访问管理
1	安全管理员	符合	3	3	1	3	1
		部分符合	0	0	0	0	0
		不符合	0	0	0	0	0
		不适用	0	0	0	0	0

4.8.2 结果分析

安全保护措施：

人员安全管理方面人员录用采取严格的考试制度，审查人员资质是否符合岗位标准，录用前经过培训上岗，人员资料留于本公司及上级公司，签署保密协议；人员离岗收回人员对系统的访问及操作所有权限，收回上岗证及与工作相关的证件、硬件设备，回收完毕后才可离岗；所有在岗人员均实行人员考核制度；公司不定期对人员组织进行安全意识和教育方面培训，包括系统安全，作业安全等；对外来访问人员进行安全培训后才可作业，并全程监督，登记备案。

4.9 系统建设管理

4.9.1 结果汇总

表 4-9 系统建设管理-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点								
			系统定级	安全方案设计	产品采购和使用	自行软件开发	外包软件开发	工程实施	测试验收	系统交付	安全服务商选择
1	系统建设	符合	3	4	4	0	3	2	3	3	3
		部分符合	0	0	0	0	0	0	0	0	0

		不符合	0	0	0	0	2	0	0	0	0
		不适用	0	0	0	3	0	0	0	0	0

4.9.2 结果分析

安全保护措施：

系统建设管理按电力行业要求，明确监控系统的边界和安全保护等级，定级按照电力行业标准和地调要求撰写定级报告，并通过定西市网安大队和地调的审核。系统在定级前已经按照风险评估结果进行相应整改并形成安全方案，查阅安全方案的论证和审定记录，查阅相关专家论证意见和管理层批准意见。采购的安全产品通过电力行业认证检测，加密产品通过国家保密主管部门认证。查看该单位与外包软件开发商签订的相关协议，查看软件测试、验收和相关技术文档。查看实施方案、阶段性报告、安全测试报告、测试验收报告、系统交付清单符合要求。存在的问题： 外包软件安装之前没有检测软件包中存在的恶意代码；厂商未提供电力监控系统和光功率预测系统的软件源代码备份。

安全问题：

1.外包软件安装之前没有检测软件包中存在的恶意代码

2.厂商未提供电力监控系统和光功率预测系统的软件源代码备份。

4.10 系统运维管理

4.10.1 结果汇总

表 4-10 系统运维管理-单元测评结果汇总表

序号	测评对象	符合情况	安全控制点											
			环境管理	资产管理	介质管理	设备管理	网络安全管理	系统安全管理	恶意代码防范管理	密码管理	变更管理	备份及恢复管理	安全事件处置	应急预案管理

序号	测评对象	符合情况	安全控制点											
			环境管理	资产管理	介质管理	设备管理	网络安全管理	系统安全管理	恶意代码防范管理	密码管理	变更管理	备份及恢复管理	安全事件处置	应急预案管理
1	系统运维管理	符合	4	2	5	2	3	4	1	1	1	3	4	2
		部分符合	0	0	0	3	0	0	0	0	0	0	1	0
		不符合	0	0	0	0	3	3	3	0	1	0	0	1
		不适用	0	0	0	0	0	0	0	0	0	0	0	0

4.10.2 结果分析

安全保护措施：

查看《定西市明晖新能源有限公司光伏发电站电力监控系统运维管理规定》， 厂家定期对机房内供配电、空调、温湿度控制器维护。机房 24 小时有人值守，人员和设备进出机房都需要审批并有专人陪同，并有详细记录表。查看《定西市明晖新能源有限公司光伏发电站电力监控系统安全防护管理制度》制定有完善的办公环境管理制度，对人员管理，终端管理等做了详细的规定。查看《光伏发电站台账管理制度》制定了与电力监控系统相关的完善的资产台账，所有台账分级分类进行管理。查看《定西市明晖新能源有限公司光伏发电站电力监控系统安全防护移动介质管理制度》，对介质的存放环境和控制保护作出了明确规定，对与存储介质的带出/带入有明确的手续。并对移动存储介质的使用进行了严格限制，所有介质分类存放，由光伏发电站的相关人员进行管理。对介质归档和查询等过程进行了控制，形成记录，并定期进行盘点。对于要销毁的介质会首先清除介质中的敏感数据，对于保密性较高的存储介质会向主管领导发起审批，待批准后进行销毁。查看《机房出入登记表》，由光伏发电站的相关人员对电力监控系统的相关设备进行维护。有详细的设备安全管理制度，对设备的申报、审批进行管理。查看工作票， 内容存在委托设备厂家对网络设备进行更新，更新前对重要文件做了备份。查看《光伏发电站电力监控系统安全防护远程访问管理制度》， 所有与外部系统的连接都需申请，

并且由管理员和部门领导授权和批准。根据业务需求和系统需求对系统设置了访问控制策略。委托设备厂家对系统补丁进行不定期安装，安装前，设备厂家提前在测试环境中进行了测试，并对重要文件做了备份。访谈系统管理员，数字证书由电力公司统一下发，由安全主管统一管理。查看《年度信息安全培训计划》中要求所有员工进行防病毒意识培训，《光伏发电站电力监控系统安全防护管理制度》规定外来计算机或存储设备接入系统前必须经过病毒检查。查看《光伏发电站电力监控系统安全防护岗位职责》，制定了完善的安全事件处置制度，明确了安全弱电和可疑事件的上报流程，并告知所有用户不得尝试验证弱电。查看《光伏发电站电力监控系统安全防护管理制度》，制定了完善的安全事件处置制度，明确了安全事件的上报、处置流程。查看《定西市明晖新能源有限公司光伏发电站安全防护管理制度》，按照电力行业要求对安全事件等级进行了划分。明确了安全事件的分析、避免措施等内容。建立了完善的电力二次系统联合防护和应急机制。查看《光伏发电站安全防护管理制度》、《应急预案汇编》制定了完善的应急预案，并有应急预案留存文件。每年对相关系统所有人员进行应急预案培训和演练。

安全问题：

1. 无专人对网络进行管理、分析和处理，委托设备厂家不定期进行管理、分析。
2. 没有对网络系统做漏洞扫描。
3. 没有对网络设备配置文件在安装时由厂家进行定期备份。
4. 没有定期对系统进行漏洞扫描，无漏洞扫描报告。
5. 没有建立系统安全管理制度。
6. 没有定期对运行日志和审计数据进行分析。
7. 没有恶意代码防护措施或 IDS 等相关安全类设备。
8. 没有对系统进行恶意代码检测，没有检测记录。

9. 没有安装防恶意代码软件。

10. 系统变更没有管理制度规定。

11. 没有建立电力系统联合防护和应急预案，也没有进行过演练。

4.11 特殊指标

本次测评无特殊指标。

4.12 单元测评小结

4.12.1 控制点符合情况汇总

根据附录 A 中测评项的符合程度得分，以算术平均法合并多个测评对象在同一测评项的得分，得到各测评项的多对象平均分。

根据测评项权重（参见附件《测评项权重赋值表》，其他情况的权重赋值另行发布），以加权平均合并同一安全控制点下的所有测评项的符合程度得分，并按照控制点得分计算公式得到各安全控制点的 5 分制得分。

$$控制点得分=\frac{\sum_{=1}^{n} 测评项的多对象平均分\times测评项权重}{\sum_{=1}^{n} 测评项权重}$$，n 为同一控制点下的测评项数，不含不适用的控制点和测评项。

以表格形式汇总测评结果，表格以不同颜色对测评结果进行区分，部分符合（安全控制点得分在 0 分和 5 分之间，不等于 0 分或 5 分）的安全控制点采用黄色标识，不符合（安全控制点得分为 0 分）的安全控制点采用红色标识。

表 4-11 单元测评结果分类统计表

序号	安全层面	安全控制点	安全控制点得分	符合情况			
				符合	部分符合	不符合	不适用
1	物理安全	物理位置的选择	5.0	√			

序号	安全层面	安全控制点	安全控制点得分	符合情况			
				符合	部分符合	不符合	不适用
2		物理访问控制	5.0	√			
3		防盗窃和防破坏	5.0	√			
4		防雷击	5.0	√			
5		防火	5.0	√			
6		防水和防潮	5.0	√			
7		防静电	5.0	√			
8		温湿度控制	5.0	√			
9		电力供应	5.0	√			
10		电磁防护	5.0	√			
11	网络安全	结构安全	5.0	√			
12		边界完整性检查	2.0		√		
13		入侵防范	0			√	
14		访问控制	5.0	√			
15		安全审计	4.7		√		
16		网络设备防护	3.9		√		
17	主机安全	身份鉴别	4.4		√		
18		访问控制	5.0	√			
19		安全审计	5.0	√			
20		入侵防范	2.8		√		
21		恶意代码防范	2.2		√		
22		资源控制	3.4		√		
23	应用安全	身份鉴别	4.6		√		
24		访问控制	5.0	√			

序号	安全层面	安全控制点	安全控制点得分	符合情况			
				符合	部分符合	不符合	不适用
25		安全审计	0			√	
26		通信完整性	5.0	√			
27		通信保密性	0.9		√		
28		软件容错	1.7		√		
29		资源控制	0			√	
30	数据安全及备份恢复	数据完整性	5.0	√			
31		数据保密性	5.0	√			
32		备份和恢复	5.0	√			
33	安全管理制度	管理制度	5.0	√			
34		制定和发布	5.0	√			
35		评审和修订	3.0		√		
36	安全管理机构	岗位设置	5.0	√			
37		人员配备	3.3		√		
38		授权和审批	5.0	√			
39		沟通和合作	5.0	√			
40		审核和检查	5.0	√			
41	人员安全管理	人员录用	5.0	√			
42		人员离岗	5.0	√			
43		人员考核	5.0	√			
44		安全意识教育和培训	5.0	√			
45		外部人员访问管理	5.0	√			
46	系统建设管理	系统定级	5.0	√			
47		安全方案设计	5.0	√			

序号	安全层面	安全控制点	安全控制点得分	符合情况			
				符合	部分符合	不符合	不适用
48		产品采购	5.0	√			
49		自行软件开发	N/A				√
50		外包软件开发	4.2		√		
51		工程实施	5.0	√			
52		测试验收	5.0	√			
53		系统交付	5.0	√			
54		安全服务商选择	5.0	√			
55	系统运维管理	环境管理	5.0	√			
56		资产管理	5.0	√			
57		介质管理	5.0	√			
58		设备管理	4.5		√		
60		网络安全管理	1.4		√		
61		系统安全管理	2.8		√		
62		恶意代码防范管理	1.1		√		
63		密码管理	5.0	√			
64		变更管理	3.6		√		
65		备份与恢复管理	5.0		√		
66		安全事件处置	4.3		√		
67		应急预案管理	2.5		√		

4.12.2 安全问题汇总

针对单元测评结果中存在的部分符合项或不符合项加以汇总，形成安全问题列表并计算其严重程度值。依其严重程度取值为 1~5，最严重的取值为 5。安全问题

严重程度值是基于对应的测评项权重并结合附录A 中对应测评项的符合程度进行的。具体计算公式如下：

安全问题严重程度值=（5-测评项符合程度得分）×测评项权重。

表 4-12 安全问题汇总表

问题编号	安全问题	测评对象	安全层面	安全控制点	测评项	测评项权重	问题严重程度值
W001	边界处部署网络安全监测装置，可发现私自连接内部网络的行为，但对其行为没有任何操作	网络全局	网络安全	边界完整性检查	a）应能够对非授权设备私自联到内部网络的行为进行检查，准确定出位置，并对其进行有效阻断；	1	3
W002	网络边界处没有入侵防范等任何安全设备	网络全局	网络安全	入侵防范	a）应在网络边界处监视以下攻击行为：端口扫描、强力攻击、木马后门攻击、拒绝服务攻击、缓冲区溢出攻击、IP 碎片攻击和网络蠕虫攻击等；	1	5
W003	网络设备默认开启 telnet 功能	一平面实时交换机 二平面实时交换机 二平面非实时交换机 控制区交换机 内网交换机 一平面路由器 二平面路由器	网络安全	网络设备防护	a）应对登录网络设备的用户进行身份鉴别；	0.5	0.5
W004	网络设备设置管理员用户，但未对登录地址进行限制	一平面实时交换机 二平面实时交换机 二平面非实时交换机	网络安全	网络设备防护	b）应对网络设备的管理员登录地址进行限制；	0.5	2.5

		控制区交换机 内网交换机 外网交换机 一平面路由器 二平面路由器 一平面省调实时纵向加密 一平面地调实时纵向加密 二平面非实时纵向加密 反向隔离装置 控制区网安监测装置 非控制区网安监测装置					
W005	网络设备口令不定期进行更换，没有定期进行更换	全部网络设备	网络安全	网络设备防护	d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储；	1	2
W006	没有启用安全审计 功能，审计记录应包括事件的日期和时间、用户、事件类型等	反向隔离装置	网络安全	安全审计	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。 应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进 行日志记录；	1	5
W007	管理员设置了符合口令长度和复杂	监控服务器 光功率预测服务器	主机安全	身份鉴别	b) 操作系统和数据库系统管理用	0.5	2.5

	度的口令，但操作系统采用默认口令策略，未设置口令复杂度策略。	光功率气象服务器 气象服务器终端			户身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。口令长度不得小于 8 位，且为字母、数字或特殊字符的混合组合，用户名和口令禁止相同；（增强）		
W008	气象服务器终端采用默认的帐户锁定策略，未设置锁定策略。	气象服务器终端	主机安全	身份鉴别	c) 应启用登录失败处理功能，可采取结束会话、限制非法登录次数和自动退出等措施；限制同一用户连续失败登录次数；	1	5
W009	未遵循最小安装原则，安装多余的程序或组件，未及时升级更新服务器的补丁，开放了多余的端口（如 135、445）。	监控服务器 气象服务器终端	主机安全	入侵防范	a)操作系统应遵循最小安装的原则，仅安装必要的组件和应用程序，并通过设置升级服务器等方式保持系统补丁及时得到更新，补丁安装前应进行安全性和兼容性测试。（增强）	1	5
W010	未安装防病毒软件。	监控服务器 光功率预测服务器 光功率气象服务器 气象服务器终端	主机安全	恶意代码防范	a) 应安装防恶意代码软件，并及时更新防恶意代码软件版本和恶意代码库。应在本机安装防恶意代码软件或独立部署恶意代码防护设备，并及时更新防恶意代码软件版本和恶意代码库；（增强）	1	5

W011	未设置登录终端超时锁定。	光功率预测服务器 光功率气象服务器 气象服务器终端	主机安全	资源控制	b) 应根据安全策略设置登录终端的操作超时锁定；	0.5	2.5
W012	未设置密码复杂度策略	功率预测系统 光功率预测系统	应用安全	身份鉴别	e) 应启用身份鉴别、用户身份标识唯一性检查、用户身份鉴别信息复杂度检查以及登录失败处理功能， 并根据安全策略配置相关参数。	0.5	1
W013	系统没有开启审计功能	功率预测系统 光功率预测系统	应用安全	安全审计	a）应提供覆盖到每个用户的安全审计功能，对应用系统的用户登录、用户退出、增加用户、修改用户权限等重要安全事件进行审计；	1	5
W014	系统没有利用加密技术对存储和传输数据进行加密	功率预测系统	应用安全	通信保密性	a) 在通信双方建立连接之前，应用系统应利用密码技术进行会话初始化验证	0.5	2.5
W015	整个会话没有进行加密	功率预测系统 光功率预测系统	应用安全	通信保密性	b) 应对通信过程中的整个报文或会话过程进行加密	1	5
W016	系统没有使用接口传输数据，并没有规定传输接口的固定字段	功率预测系统 光功率预测系统	应用安全	软件容错	a）应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的数据格式或长度符合系统设定要求	1	5
W017	电力监控系统需要每隔 15 分钟查看信息，不会自动结束会话	功率预测系统	应用安全	资源控制	a）当应用系统的通信双方中的一方在一段时间内未作任何响应，另一方应能够自动 结束会话	0.5	2.5

W018	系统没有对系统的最大并发会话连接数进行限制	光功率预测系统	应用安全	资源控制	b）应能够对系统的最大并发会话连接数进行限制	0.5	2.5
W019	系统业务峰值为单用户操作。没有对单个帐户的多重并发会话进行限制	功率预测系统	应用安全	资源控制	c）应能够对单个帐户的多重并发会话进行限制	0.2	1
W020	安全管理员属于兼职	光伏监控系统光功率预测系统	安全管理机构	人员配备	安全管理员不能兼任网络管理员、系统管理员、数据库管理员等	0.5	2.5
W021	外包软件安装之前没有检测软件包中存在的恶意代码	光伏监控系统光功率预测系统	系统建设管理	外包软件开发	系统没有检测恶意代码可能导致系统留存后门或漏洞。	1	5
W022	厂商未提供电力监控系统和光功率预测系统的软件源代码备份	光伏监控系统光功率预测系统	系统建设管理	外包软件开发	厂商没有提供源代码，可能导致由于代码层面导致的逻辑问题被利用的威胁。	1	5
W023	无专人对网络进行 管理、分析和处理，委托设备厂家不定期进行管理、分析	光伏监控系统光功率预测系统	系统运维管理	网络安全管理	应指定人员/专人对网络进行管理，负责运行日志、网络监控记录的日常维护和报警信息分析和处理工作；	1	5
W024	没有建立网络安全管理制度	光伏监控系统光功率预测系统	系统运维管理	网络安全管理	应建立网络安全管理制度，对网络安全配置、日志保存时间、安全策略、升级与打补丁、口令更新周期等方面作出规定；	0.5	2.5
W025	没有对网络系统做漏洞扫描	光伏监控系统光功率预测系统	系统运维管理	网络安全管理	应定期对网络系统进行漏洞扫描，对发现的网络系统安全漏洞进行	1	5

					及时的修补；		
W026	没有网络设备备份的管理制度，但是电厂在厂商部署和维护过程中，会让维护人员保守 操作，存在配置文件 备份，并在工作票和实施方案中有此内容。	光伏监控系统光功率预测系统	系统运维管理	网络安全管理	应对网络设备的配置文件进行定期备份	0.5	2.5
W027	没有对系统做漏洞扫描	光伏监控系统光功率预测系统	系统运维管理	网络安全管理	应定期进行漏洞扫描，对发现的系统安全漏洞及时进行修补	1	5
W028	没有建立系统安全管理制度	光伏监控系统光功率预测系统	系统运维管理	系统安全管理	应建立系统安全管理制度，对系统安全策略、安全配置、日志管理和日常操作流程等方面作出具体规定；	0.5	2.5
W029	没有建立系统操作和维护系统安全管理制度	光伏监控系统光功率预测系统	系统运维管理	系统安全管理	应依据操作手册对系统进行维护，详细记录操作日志，包括重要的日常操作、运行维护记录、参数的设置和修改等内容，严禁进行未经授权的操作；	1	5
W030	没有制定变更方案制度	光伏监控系统光功率预测系统	系统运维管理	变更管理	应确认系统中要发生的变更，并制定变更方案；	0.2	1
W031	没有建立变更管理制度	光伏监控系统光功率预测系统	系统运维管理	变更管理	系统发生重要变更前，应向主管领导申请，审批后方可实施变更，并在实施后向相关人员通告	0.5	2.5
W032	没有建立备份与恢复管理制度	光伏监控系统光功率预测系统	系统运维管理	备份和恢复管	应建立备份与恢复管理相关的安全管理制度，对备	0.5	2.5

				理	份信息的备份方式、备份频度、存储介质和保存期等进行规范；		
W033	没有指定数据的备份策略和恢复策略	光伏监控系统光功率预测系统	系统运维管理	备份和恢复管理	应根据数据的重要性和数据对系统运行的影响，制定数据的备份策略和恢复策略，备份策略须指明备份数据的放置场所、文件命名规则、介质替换频率和将数据离站运输的方法；	0.5	2.5

5 整体测评

从安全控制间、层面间、区域间和验证测试等方面对单元测评的结果进行验证、分析和整体评价。

具体内容参见《GB/T 28448-2012 信息安全技术信息系统安全等级保护测评要求》。

5.1 安全控制间安全测评

安全控制间的安全测评主要考虑同一区域内、同一层面上的不同安全控制间存在的功能增强、补充或削弱等关联作用。安全功能上的增强和补充可以使两个不同强度、不同等级的安全控制发挥更强的综合效果，可以使单个低等级安全控制在特定环境中达到高等级信息系统的安全要求。安全功能上的削弱可能会使一个安全控制的引入影响另一个安全控制的功能发挥或者给其带来新的脆弱性，使其在特定环境中不能达到该等级信息系统的安全要求。

序号	层面	安全控制间安全测评内容	说明
1	网络安全	安全审计和安全审计	反向隔离装置没有启用审计功能，但网络中网络安全监测装置对反向隔离装置进行了审计功能，对反向隔离装置的审计功能起到了弥补作用。

5.2 层面间安全测评

层面间的安全测评主要考虑同一区域内的不同层面之间存在的功能增强、补充和削弱等关联作用。安全功能上的增强和补充可以使两个不同层面上的安全控制发挥更强的综合效能，可以使单个低等级安全控制在特定环境中达到高等级信息系统

的安全要求。安全功能上的削弱会使一个层面上的安全控制影响另一个层面安全控制的功能发挥或者给其带来新的脆弱性。

序号	层面间安全测评内容	说明
1	网络安全与主机安全	1） 由于在网络中部署防火墙、集成防病毒模块的防火墙，服务器上未安装防恶意代码，因此网络中所部署的恶意代码防范产品对主机防护具有一定的弥补作用。

5.3 区域间安全测评

区域间的安全测评主要考虑互连互通（包括物理上和逻辑上的互连互通等）的不同区域之间存在的安全功能增强、补充和削弱等关联作用，特别是有数据交换的两个不同区域。安全功能上的增强和补充可以使两个不同区域上的安全控制发挥更强的综合效能，可以使单个低等级安全控制在特定环境中达到高等级信息系统的安全要求。安全功能上的削弱会使一个区域上的安全功能影响另一个区域安全功能的发挥或者给其带来新的脆弱性。

经过分析，该功率预测系统各功能区域完整，网络边界清晰，安全措施比较到位，能够在一定程度上满足业务的使用需要和安全需要。系统不存在区域间的功能增强、补充和削弱等关联关系。

5.4 验证测试

本次测评过程定西市明晖新能源有限公司因考虑到功率预测系统的稳定性放弃了漏洞扫描和渗透测试工作，“自愿放弃验证测试声明”详见附录 B。

5.5 整体测评结果汇总

根据整体测评结果，修改安全问题汇总表中的问题严重程度值及对应的修正后测评项符合程度得分，并形成修改后的安全问题汇总表（仅包括有所修正的安全问题）。可根据整体测评安全控制措施对安全问题的弥补程度将修正因子设为 0.5~0.9。

修正后问题严重程度值=修正前的问题严重程度值×修正因子。

修正后测评项符合程度=5-修正后问题严重程度值/测评项权重

表 5-1 修正后的安全问题汇总表

序号	问题编号	安全问题描述	测评项权重	整体测评描述	修正因子	修正后问题严重程度值	修正后测评项符合程度
1	W006	没有启用安全审计功能， 审计记录应包括事件的日期和时间、用户、事件类型等。	1	反向隔离装置没有启用审计功能，但网络中网安检测装置对反向隔离装置进行了审计功能，对反向隔离装置的审计功能起到了弥补作用。	0.5	2.5	2.5
2	W010	未安装防病毒软件。	1	由于在网络中部署防火墙、集成了防病毒模块，服务器上未安装防恶意代码，因此网络中所部署的恶意代码防范产品对主机防护具有一定的弥补作用。	0.5	2.5	2.5

6 总体安全状况分析

6.1 系统安全保障评估

根据附录A 中各单元测评的符合情况得分及部分符合和不符合项的修正后测评项符合程度得分情况，通过相关公式得出同一安全控制点下的所有测评项的符合程度得分，并按照控制点得分计算公式得到各安全控制点的 5 分制得分，通过公式同一安全层面下的所有安全控制点得分，并转换成各安全层面的百分制得分。系统安全保障情况得分表详见下表所示：

表 6-1 系统安全保障情况得分表

序号	安全层面	安全控制点	安全控制点得分	安全层面得分
1	物理安全	物理位置的选择	5.0	100
2		物理访问控制	5.0	
3		防盗窃和防破坏	5.0	
4		防雷击	5.0	
5		防火	5.0	
6		防水和防潮	5.0	
7		防静电	5.0	
8		温湿度控制	5.0	
9		电力供应	5.0	
10		电磁防护	5.0	
11	网络安全	结构安全	5.0	68.7
12		边界完整性检查	2.0	
13		入侵防范	0	
14		访问控制	5.0	
15		安全审计	4.7	

序号	安全层面	安全控制点	安全控制点得分	安全层面得分
16		网络设备防护	3.9	
17	主机安全	身份鉴别	4.4	75.7
18		访问控制	5.0	
19		安全审计	5.0	
20		入侵防范	2.8	
21		恶意代码防范	2.2	
22		资源控制	3.4	
23	应用安全	身份鉴别	4.6	49.1
24		访问控制	5.0	
25		安全审计	0	
26		通信完整性	5.0	
27		通信保密性	0.9	
28		软件容错	1.7	
29		资源控制	0	
30	数据安全及备份恢复	数据完整性	5.0	100
31		数据保密性	5.0	
32		数据备份与恢复	5.0	
33	安全管理制度	管理制度	5.0	100
34		制定和发布	5.0	
35		评审和修订	5.0	
36	安全管理机构	岗位设置	5.0	85.2
37		人员配备	3.3	
38		资金保障	5.0	
39		授权和审批	5.0	
40		沟通和合作	3.0	

序号	安全层面	安全控制点	安全控制点得分	安全层面得分
41		审核和检查	5.0	
42	人员安全管理	人员录用	5.0	100
43		人员离岗	5.0	
44		人员考核	5.0	
45		安全意识教育和培训	5.0	
46		外部人员访问管理	5.0	
47	系统建设管理	系统定级	5.0	98.1
48		安全方案设计	5.0	
49		产品采购	5.0	
50		自行软件开发	N/A	
51		外包软件开发	4.2	
52		工程实施	5.0	
53		测试验收	5.0	
54		系统交付	5.0	
55		安全服务商选择	5.0	
56	系统运维管理	环境管理	5.0	75.3
57		资产管理	5.0	
58		介质管理	5.0	
59		设备管理	4.5	
60		网络安全管理	1.4	
61		系统安全管理	2.8	
62		恶意代码防范管理	1.1	
63		密码管理	5.0	
64		变更管理	3.6	
65		备份与恢复管理	5.0	
66		安全事件处置	4.3	

序号	安全层面	安全控制点	安全控制点得分	安全层面得分
67		应急预案管理	2.5	

6.2 安全问题风险评估

依据信息安全标准规范，采用风险分析的方法进行危害分析和风险等级判定。针对等级测评结果中存在的所有安全问题，结合关联资产和威胁分别分析安全危害，找出可能对信息系统、单位、社会及国家造成的最大安全危害（损失），并根据最大安全危害严重程度进一步确定信息系统面临的风险等级，结果为“高”、“中”或“低”。并以列表形式给出等级测评发现安全问题以及风险分析和评价情况，详见下表所示：

表 6-2 信息系统安全问题风险分析表

问题编号	安全层面	问题描述	关联资产	关联威胁	危害分析结果	风险等级
W001	网络安全	边界处部署网络安全监测装置，可发现私自连接内部网络的行为，但对其行为没有任何操作	网络全局	T5T6	不能对自己接入电力网络的设备进行控制和管理。	中
W002	网络安全	网络边界处没有入侵防范等任何安全设备	网络全局	T5	不能抵挡网络攻击行为，如端口扫描、强力攻击、木马后门攻击、拒绝服务攻击等。	中
W003	网络安全	网络设备默认开启 telnet 功能	一平面实时交换机 二平面实时交换机 二平面非实时交换机 控制区交换机 内网交换机 一平面路由器 二平面路由器	T6T7	由于 telnet 的安全性较低，容易被攻击利用，建议关闭 telnet 功能。	中
W004	网络安全	网络设备设置管理员用户，但未对登录地址进行限制	一平面实时交换机 二平面实时交换机	T6T7	只要破解登陆口令及密码，任何计算机均可登陆网络设备进行配置。容易被攻击者远程	中

问题编号	安全层面	问题描述	关联资产	关联威胁	危害分析结果	风险等级
			二平面非实时交换机 控制区交换机 内网交换机 外网交换机 一平面路由器 二平面路由器 一平面省调实时纵向加密 一平面地调实时纵向加密 二平面非实时纵向加密 反向隔离装置 控制区网安监测装置 非控制区网安监测装置		利用。	
W005	网络安全	网络设备口令不定期进行更换，没有定期进行更换	全部网络设备	T6T7	如果不满足强口令要求，且口令没有定期更换，可能会导致非授权访问系统资源，或者用户或者业务数据被窃取	中
W006	网络安全	没有启用安全审计功能，审计记录应包括事件的日期和时间、用户、事件类型等	反向隔离装置	T6	没有审计功能可导致设备有问题无法进行追溯，无法判定事故来源等信息。	低
W007	主机安全	管理员设置了符合口令长度和复杂度的口令，但操作系统采用默认口令策略，未设置口令复杂度策略。	监控服务器 光功率预测服务器 光功率气象服务器 气象服务器终端	T7	口令可能被恶意用户猜测获得，合法用户身份被仿冒，导致系统被非授权访问。	中
W008	主机安全	气象服务器终端采用默认的帐户锁定策略， 未设置锁定策略。	气象服务器终端	T6	身份鉴别机制不完善，使合法用户的鉴别信息更容易被攻击者所获取，从而使合法用户身份被冒用，对相关系统的正常运行带来影	低

问题编号	安全层面	问题描述	关联资产	关联威胁	危害分析结果	风险等级
					响。	
W009	主机安全	未遵循最小安装原则，安装多余的程序或组件，未及时升级更新服务器的补丁，开放了多余的端口（如135、445）。	监控服务器 气象服务器 终端	T5	多组件或服务可能存在安全漏洞，或影响服务器性能，不易发现系统安全隐患。	中
W010	主机安全	未安装防病毒软件。	监控服务器 光功率预测服务器 光功率气象服务器 气象服务器 终端	T5	缺乏统一的病毒监控机制将不利于管理员掌握系统内各主机操作系统的病毒防护现状，无法在病毒暴发时采取及时的应对措施。	中
W011	主机安全	未设置登录终端超时锁定。	光功率预测服务器 光功率气象服务器 气象服务器 终端	T6	如果用户登录服务器、数据库后未退出或锁定而离开电脑，可能导致恶意用户非授权访问服务器。	低
W012	应用安全	未设置密码复杂度策略	功率预测系统 光功率预测系统	T1	如果没有登录失败处理功能，可能会导致非授权访问系统资源，或者用户或者业务数据被窃取	中
W013	应用安全	系统没有开启审计功能	功率预测系统 光功率预测系统	T1T3	如果未关闭不需要的网络服务，可能会导致非授权访问系统资源，或者用户或者业务数据被窃取	中
W014	应用安全	系统没有利用加密技术对存储和传输数据进行加密	功率预测系统	T1	如果没有审计功能，一旦发生安全事件，事后无法对事件进行有效的追溯，并获取完整的可用信息	中
W015	应用安全	整个会话没有进行加密	功率预测系统 光功率预测系统	T1	如果没有审计功能，一旦发生安全事件，事后无法对事件进行有效的追溯，并获取完整的可用信息	中

问题编号	安全层面	问题描述	关联资产	关联威胁	危害分析结果	风险等级
W016	应用安全	系统没有使用接口传输数据，并没有规定传输接口的固定字段	功率预测系统 光功率预测系统	T1	如果不满足强口令要求，且口令没有定期更换，可能会导致非授权访问系统资源，或者用户或者业务数据被窃取	中
W017	应用安全	电力监控系统需要每隔 15 分钟查看信息，不会自动结束会话	功率预测系统	T1	如果没有登录失败处理功能，可能会导致非授权访问系统资源，或者用户或者业务数据被窃取	中
W018	应用安全	系统没有对系统的最大并发会话连接数进行限制	光功率预测系统	T1	如果没有启用访问控制功能，现在用户对资源的访问，可能会导致非授权访问系统资源，或者用户或者业务数据被窃取	中
W019	应用安全	系统业务峰值为单用户操作。没有对单个帐户的多重并发会话进行限制	功率预测系统	T1	如果没有审计功能，一旦发生安全事件，事后无法对事件进行有效的追溯，并获取完整的可用信息	中
W020	安全管理机构	安全管理员属于兼职	光伏监控系统 光功率预测系统	T4	如果安全管理员兼任网络管理员、系统管理员、数据库管理员，可能会导致权限分配不均，数据泄露等	低
W021	系统建设管理	外包软件安装之前没有检测软件包中存在的恶意代码	光伏监控系统 光功率预测系统	T5	系统没有检测恶意代码可能导致系统留存后门或漏洞。	中
W022	系统建设管理	厂商未提供电力监控系统和光功率预测系统的软件源代码备份	光伏监控系统 光功率预测系统	T5	厂商没有提供源代码，可能导致由于代码层面导致的逻辑问题被利用的威胁。	中
W023	系统运维管理	无专人对网络进行管理、分析和处理，委托设备厂家不定期	光伏监控系统 光功率预测系统	T4	如果没有指定人员/专人对网络进行管理，负责运行日志、网络监控记录的日常维护和报	低

问题编号	安全层面	问题描述	关联资产	关联威胁	危害分析结果	风险等级
		进行管理、分析			警信息分析和处理工作，可能对安全事件的责任无法确认；	
W024	系统运维管理	没有建立网络安全管理制度	光伏监控系统 光功率预测系统	T4	如果没有建立网络安全管理制度，对网络安全配置、日志保存时间、安全策略、升级与打补丁、口令更新周期等方面作出规定，可能会导致网络安全的管理混乱；	低
W025	系统运维管理	没有对网络系统做漏洞扫描	光伏监控系统 光功率预测系统	T4	如果不定期对网络系统进行漏洞扫描，可能会导致网络系统安全漏洞进行不能及时的修补；	低
W026	系统运维管理	没有网络设备备份的管理制度，但是电厂在厂商部署和维护过程中，会让维护人员保守操作，存在配置文件备份，并在工作票和实施方案中有此内容。	光伏监控系统 光功率预测系统	T4	如果对网络设备的配置文件进行不定期备份，可能会导致设备出故障无法及时配置，业务无法及时恢复。	低
W027	系统运维管理	没有对系统做漏洞扫描	光伏监控系统 光功率预测系统	T4	如果不定期对系统进行漏洞扫描，可能会导致网络系统安全漏洞进行不能及时的修补；	低
W028	系统运维管理	没有建立系统安全管理制度	光伏监控系统 光功率预测系统	T4	应建立系统安全管理制度，对系统安全策略、安全配置、日志管理和日常操作流程等方面作出具体规定；	低
W029	系统运维管理	没有建立系统操作和维护系统安全管理制度	光伏监控系统 光功率预测系统	T4	对系统稳定性和可控制性造成影响，无法确定操作人，操作对象，出问题无法进行追溯。	低
W030	系统运维管理	没有制定变更方案制度	光伏监控系统 光功率预测系统	T4	如果没有对确认系统中要发生的变更，并制定变更方案，可能会导致系统变更失败无法	低

问题编号	安全层面	问题描述	关联资产	关联威胁	危害分析结果	风险等级
					恢复；	
W031	系统运维管理	没有建立变更管理制度	光伏监控系统 光功率预测系统	T4	如果没有在系统发生重要变更前，应向主管领导申请，审批后方可实施变更，并在实施后向相关人员通告，可能会导致系统管理人员随意更改系统。	低
W032	系统运维管理	没有建立备份与恢复管理制度	光伏监控系统 光功率预测系统	T4	如果没有建立备份与恢复管理相关的安全管理制度，对备份信息的备份方式、备份频度、存储介质和保存期等进行规范，可能会导致数据没有备份，数据丢失后无法恢复；	低
W033	系统运维管理	没有指定数据的备份策略和恢复策略	光伏监控系统 光功率预测系统	T4	如果没有数据的备份策略和恢复策略，可能会导致数据备份管理混乱；	低

6.3 等级测评结论

通过本次等级测评可以看出，光伏监控系统已经具备了一定的信息安全保障能力，初步形成了覆盖安全技术与安全管理两大方面的防御体系，在物理安全、网络安全、主机安全、应用安全、数据安全和安全管理制度、安全管理机构、人员安全管理、系统建设管理、系统运维管理等方面已采取了一些较为有效的安全措施。在这些安全措施的有效保护下，光伏监控系统基本可以保护系统抵御外部的部分信息安全攻击行为，能够发现并处置大部分安全行为，在系统遭到损害后，也能够较快恢复绝大部分功能。

但是，光伏监控系统的一些关键资产仍存在部分脆弱性，且现有安全措施仍然存在薄弱的环节，会给系统带来一定的安全隐患，其业务的连续性仍面临着不安全的挑战。

通过本次等级测评可以看到，光伏监控系统基本满足《电力行业信息系统安全等级保护基本要求》第二级（S2A2G2）的要求。因此，本次定西市明晖新能源有限公司的光伏监控系统的等级保护测评结论为：基本符合，综合得分为：85.2。

测评结论	判别依据	综合得分
基本符合	信息系统中存在安全问题，但不会导致信息系统面临高等级安全风险	85.2 分

7 问题处置建议

7.1 网络安全

序号	问题描述	整改建议
1	边界处部署网络安全监测装置，可发现私自连接内部网络的行为，但对其行为没有任何操作	建议增加入网准入设备，控制网络入口
2	网络边界处没有入侵防范等任何安全设备	建议增加网络控制设备，可抵抗网络入侵
3	网络设备默认开启 telnet 功能	建议关闭 telnet 功能进行安全防护
4	网络设备设置管理员用户，但未对登录地址进行限制	建议只是固定IP 或者固定IP 段对网络设备管理员权限进行访问
5	网络设备口令不定期进行更换，没有定期进行更换	建议每三个月进行设备密码的更换
6	反向隔离没有启用安全审计功能，审计记录应包括事件的日期和时间、用户、事件类型等	建立启动安全审计功能，审计内容包含事件的日期和时间、用户、事件类型等

7.2 主机安全

序号	问题描述	整改建议
1	操作系统和数据库系统管理用户身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。口令长度不得小于 8 位，且为字母、数字或特殊字符的混合组合，用户名和口令禁止相同；	建议强化操作系统的密码策略，加强用户口令长度与复杂度要求，并定期更换，降低受到口令猜测、非授权访问的风险。
2	应启用登录失败处理功能，可采取结束会话、限制非法登录次数和自动退出等措施；限制同一用户连续	建议开启失败登录处理功能，如限制非法登录三次、自动退出功能、锁定时间等。

序号	问题描述	整改建议
	失败登录次数；	
3	操作系统应遵循最小安装的原则，仅安装必要的组件和应用程序，并通过设置升级服务器等方式保持系统补丁及时得到更新，补丁安装前应进行安全性和兼容性测试。	服务器未遵循最小安装原则，安装多余的程序或组件，未及时升级更新服务器的补丁，开放了多余的端口（如 135、445）。上述端口是勒索病毒 Wanna Cry 的主要利用端口，不必要的端口可能存在被恶意用户利用的风险。
4	应在本机安装防恶意代码软件或独立部署恶意代码防护设备，并及时更新防恶意代码软件版本和恶意代码库；	建议部署网络恶意代码防护产品和主机防病毒软件，并通过病毒监控中心对服务器病毒感染情况进行监控。定期更新防病毒软件特征库降低主机感染病毒、木马的风险。
5	应根据安全策略设置登录终端的操作超时锁定；	系统未设置登录终端的超时锁定功能。如果用户登录操作系统后未退出或锁定而离开电脑，可能导致恶意用户非授权访问操作系统等。

7.3 安全管理机构

序号	问题描述	整改建议
1	安全管理员不能兼任网络管理员、系统管理员、数据库管理员等	建议设置专职安全管理员

7.4 应用安全

序号	问题描述	整改建议
1	采取用户名+密码的方式进行登录，对用户身份进行鉴别，修改密码未设置密码复杂度策略	系统修改密码时提供密码口令长度和复杂度判断，强行执行不满足不给与修改密码和登陆功能
2	系统没有审计功能，审计内容覆盖到每个用户的安全审计功能，对应用系统的用户登录、用户退出、增加用户、修改用户权限等	建议系统开启审计功能，审计内容覆盖到每个用户的安全审计功能，对应用系统的用户登录、用户退出、增加用户、修改用

序号	问题描述	整改建议
	重要安全事件进行审计	户权限等重要安全事件进行审计
3	系统为 C/S 架构，固定 IP 地址/端口进行通信，没有利用密码技术进行会话初始化验证	建立会话开始和结束是添加加密解密处理
4	系统没有对通信过程中的用户口令、会话密钥等敏感信息字段进行加密	建议整个会话过程均使用加密传输和存储
5	系统未提供数据有效性检验功能，如固定字段传输、字段长度等	系统未设定固定接口传输数据，接口类型未固定
6	系统需要每隔 15 分钟查看信息，没有自动结束会话功能	建议系统添加长时间未使用自动结束会话功能
7	系统没有对系统的最大并发会话连接数进行限制	建议系统线程出添加会话并发数量的链接限制
8	系统业务峰值为单用户操作。没有对单个帐户的多重并发会话进行限制	建议系统线程出添加多个会话并发的线程优先级限制

7.5 系统建设管理

序号	问题描述	整改建议
1	外包软件安装之前没有检测软件包中存在的恶意代码	建议及时做外包软件恶意代码检测
2	厂商未提供电力监控系统和光功率预测系统的软件源代码备份	建议向厂家追要外包软件源代码并进行本地备份。

7.6 系统运维管理

序号	问题描述	整改建议
1	无专人对网络进行管理、分析和处理，委托设备厂家不定期进行管理、分析。	建议设置网络管理员专门对网络进行管理，并对运行日志、记录及报警等信息进行分析和处理
2	没有对网络系统做漏洞扫描。	建议光伏发电站定期对网络系统进行漏洞扫描，并及时的修补；
3	没有对网络设备配置文件在安装时由厂家进行定期备份。	建议对所有网络设备的配置文件进行定期备份。
4	没有定期对系统进行漏洞扫描，无漏洞扫描报告。	建议定期对系统做漏洞扫描，针系统漏洞做相应修复工作。

序号	问题描述	整改建议
5	没有建立系统安全管理制度。	建议制定系统安全管理制度，规定系统安全策略、安全配置问题。
6	没有定期对运行日志和审计数据进行分析。	建议指定专人对网络和主机进行恶意代码检测并保存检测记录
7	没有恶意代码防护措施或 IDS 等相关安全类设备。	建议使用软件或硬件设备增加系统防恶意代码功能。
8	没有对系统进行恶意代码检测，没有检测记录。	建议对系统进行防恶意代码检测，保留检测记录。
9	没有安装防恶意代码软件。	建议对防恶意代码软件授权使用、定期升级、定期汇报等作出明确规定；
10	系统变更没有管理制度规定。	建议建立完善的变更方案，并严格执行
11	没有建立电力系统联合防护和应急预案，也没有进行过演练。	建议制定电力二次系统联合防护和应急处置预案，并定期进行演练

附录 A 等级测评结果记录

A.0 总体安全

测评对象	安全控制点	测评指标	结果记录	符合程度
功率预测系统	总体技术	a）电力生产企业、电网企业、供电企业内部基于计算机和网络技术的业务系统，原则上划分为生产控制大区和管理信息大区，生产控制大区可以分为控制区（又称安全区 I）和非控制区（又称 安全区Ⅱ）。	经现场检查，电站电站生产大区和管理信息大区，时实区和非实时区划分明显，不存在混插现象，各区域间存在有效隔离设备。	5
		b）生产控制大区网络与管理信息大区网络应物理隔离；两网之间有信息通信交换时应部署符合电力系统要求的单向隔离装置，确保单向隔离装置策略配置安全有效，禁止任何穿越边界的E-Mail、Web、Telnet、Rlogin、FTP 等通用网络服务。	经现场检查，管理信息大区与生产控制大区之间有国家指定的反向隔离装置。查看反向隔离装置，内外固定 IP 进行访问。禁止穿越边界的E-mail、Web、Telnet、Rlogin、FTP 等通用网络服务。	5
		c）在生产控制大区与广域网的纵向交接处应当设置经过国家指定部门检测认证的电力专用纵向加密认证装置或者加密认证网关及相应设施，确保纵向加密认证装置策略配置安全有效，实现双向身份认证、数据加密和访问控制。	经登陆设备进行检查，生产控制大区与广域网之间设置电力专用的纵向加密认证装置兴唐 SJW07-A，并进行了安全有效的配置，实现了双向身份认证、访问控制、数据加密传输，保证了数据传输的机密性和完整性。	5
		d）电力调度数据网应当在专用通道上使用独立的网络设备组网，在物理层面上实	经现场检查，电力调度数据出口处为电力专用 VPN 通道，物理层面调离调度数据网与外	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		现与其它数据网及外部公共信息网的安全隔离。	部公共信息网络物理隔离。不存在调度数据网接入互联网情况。	
		e）控制区的信息系统数据通信应使用电力调度数据网的实时子网或专用通道进行传输，非控制区的信息系统数据通信应使用电力调度数据网的非实时子网。	经现在机房线路排查，不存在应为一区的信息系统网络接入二区网络的情况，不存在应为二区的信息系统网络接入一区网络的情况。	5
		f）控制区与非控制区之间应采用国产防火墙，或采用具有访问控制功能的设备进行隔离。	经现场检查，控制区与非控制区之间存在 H3C 防火墙设备，并制定严格的访问控制策略。	5
		g）二级系统统一成域，三级及以上系统单独成域。	经现场检查，该电站所有信息系统均为二级系统，独立成域。	5
		h）三级及以上系统域由独立子网承载，每个域有唯一网络出口，可在网络出口处部署满足相应等级要求的等级保护专用装置为系统提供整体安全防护。	不适用。	N/A
		i）省级以上及有实际业务需要的地区调度中心的电力监控系统、电力调度数据网上的关键应用、关键用户和关键设备应使用电力调度数字证书系统实现身份认证、安全数据传输及鉴权。	不适用。	N/A
		j）生产控制大区所部署的安全审计系统，可对网络运行日志、操作系统运行日志、数据库访问日志、业务应用系统运行日志、安全设施运行日志等进行集中收集、自动分析。	生产控制大全部署网络安全检测装置，装置接入监控系统，光功率预测，南瑞有工，隔离装置，纵向加密装置，交换机，防火墙等。查看日志记录，可以对这些设备的日志进行收集，并有日志的类型，描述，时间等关键信息。	5

A.1 物理安全

测评对象	安全控制点	测评指标	结果记录	符合程度
机房	物理位置的选择（G2）	a）机房和办公场地应选择在具有防震、防风和防雨等能力的建筑内。	现有机房和放置终端计算机设备的办公场地的环境条件满足信息系统业务需求和安全管理需求，抗震设防不低于乙类，框架抗震等级为一级，结构安全等级为二级，防水等级为一级，主体屋面防水等级为Ⅰ级，防水层合理使用年限为 15 年，机房周围无用水设备。	5
	物理访问控制（G2）	a）机房各出入口应安排专人值守或配置电子门禁系统，控制、鉴别和记录进入的人员。	机房出入口安装门禁系统、视频监控系统，二十四小时安排人员值守，用于控制、鉴别和记录进入的人员，电子门禁系统可提供一年内记录，具有安全资质材料、安装测试和验收报告。机房出入口安全专人 24 小时进行值守，来访人员进入机房需填写《机房出入登记表》，包括来访人姓名、身份证号、单位、事由、电话、进出时间等信息，有安全管理员审批，专人全程陪同。	5
		b）需进入机房的来访人员应经过申请和审批流程，并限制和监控其活动范围。	经访谈和查看，进入机房的来访人员需要经过主任同意后方可进入，有专人陪同。来访人员需登记《访客单》，详细记录来访人员信息，其中身份证信息录入系统备查。	5
	防盗窃和防破坏（G2）	a）应将主要设备放置在机房内。	经查看：1、机房采用电子门禁和监控设备等保护措施。2、主要设备统一放置在机柜内，机柜整齐存放机房内。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b）应将设备或主要部件进行固定，并设置明显的不易除去的标记。	经检查，主要设备及设备的主要部件的固定在机柜内，均贴有明显的不易除去的标记。	5
		c）应将通信线缆铺设在隐蔽处，可铺设在地下或管道中。	经检查，通信线缆均铺设在地下桥架，强电铺设在管道中铺设，强弱电隔离铺设。	5
		d）应对介质分类标识，存储在介质库或档案室中。	经访问安全管理员和查看，存储介质（光盘、磁带）存放在档案柜内，有专人进行管理。	5
		e)主机房应装有必要的防盗报警措施。	机房安装门禁系统、视频监控系统，防止设备、介质等丢失。	5
	防雷击（G2）	a）机房建筑应设置避雷装置。	经检查，大楼通过设置避雷针（建筑物四周和楼顶)来防止雷击事件导致重要设备被破坏。	5
		b）机房应设置交流电源地线。	经检查，机房设置了交流电源地线。	5
	防火(G2）	a）机房应设置灭火设备和火灾自动报警系统。	经检查，机房配备了灭火装置（3 组），但需要手动开启。烟雾探测器已开启。火灾自动报警系统已开启。	5
	防水和防潮（G2）	a)水管安装，不得穿过机房屋顶和活动地板下。 主机房尽量避开水源，与主机房无关的给排水管道不得穿过主机房，与主机房和相关的给排水管道必须有可靠的防渗漏措施。	经访谈和查看，机房静电地板下设有水漏报警器。机房上下没有水管安装。机房未出现过漏水和返潮事件。	5
		b）应采取措施防止雨水通过机房窗户、屋顶和墙壁渗透。	经检查，机房所在屋顶和墙壁内无用水管道，未出现过漏水、渗透和返潮事件，机房及其环境不存在的漏水、渗透和返潮的现象。	5
		c）应采取措施防止机房内水蒸气结露和地下积水的转移与渗透。	机房内设有温湿度传感器，机房温度控制在 23±1℃，湿度控制在 40%-55%之间，空调系	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			统各操作维护运行记录完备，机房空调下方设有漏水检测装置，与监控中心联动，7*24小时监控，运行记录完整。	
	防静电（G2）	a）关键设备应采用必要的接地防静电措施。	经检查，机房采用了防静电地板，机柜和主要设备均有安全接地，机柜配置防静电手环。	5
	温湿度控制（G2）	机房应设置温、湿度自动调节设施，使机房温、湿度的变化在设备运行所允许的范围之内。	经检查，机房配备了温湿度传感器，机房温度控制在 23℃左右，湿度为 41%。	5
	电力供应（A2）	a）应在机房供电线路上配置稳压器和过电压防护设备。	经查看，机房供电线路安装了过流保护器和电压波涌稳定器。	5
		b）应提供短期的备用电力供应，至少满足主要设备在断电情况下的正常运行要求。	经查看， 机房配备了 UPS（4KV）备用电源提供短期备用电力供电，在断电满载情况下可以供电 4 小时。有对备用电源 UPS 做定期的检查和维护，三个月一次。并留有维修检查记录。	5
	电磁防护（S2）	a）电源线和通信线缆应隔离铺设，避免互相干扰。	经查看，通信线缆在桥架里铺设，电源线在管道中铺设，强弱电铺设间隔40cm，大于电磁干扰和耦合干扰的隔离距离。	5

A.2 网络安全

A.2.1 网络全局

测评对象	安全控制点	测评指标	结果记录	符合程度
网络全局	结构安全	a）应保证关键网络设备的业务处理能力具备冗余空间，满足业务高峰期需要。	电站业务数量较小，核心路由器为千兆路由器，在业务高峰期间 cpu 的使用率为 8%，满足	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			业务处理能力具备冗余空间。	
		b）应保证网络各个部分的带宽满足业务高峰期需要。	网络设备中带宽充足,核心网是百兆网,带宽使用率小于5%，满足业务高峰期需求。无需划分带宽。	5
		c)应绘制完整的网络拓扑结构图，有相应的网络配置表，包含设备 IP 地址等主要信息，与当前运行情况相符。	提供的网络拓扑图与当前网络运行情况相符。	5
		d)应根据各部门的工作职能、重要性和所涉及信息的重要程度等因素，划分不同的子网或网段，并按照方便管理和控制的原则为各子网、网段分配地址段。	核心交换机进行了VLAN 划分,共划分了 2 个vlan。VLAN1 涉及实时生成控制，VLAN1 与实时生产区交换机互联。VLAN2 涉及非实时生成控制。VLAN2 与非实时生产区交换机互联。	5
	边界完整性检查	a）应能够对非授权设备私自联到内部网络的行为进行检查，准确定出位置，并对其进行有效阻断。	边界处部署珠海鸿瑞（HR CRPM-3000）网络安全监测装置，可发现私自连接内部网络的行为，但对其行为没有任何阻断操作。	2
	入侵防范	a）应在网络边界处监视以下攻击行为：端口扫描、强力攻击、木马后门攻击、拒绝服务攻击、缓冲区溢出攻击、IP 碎片攻击和网络蠕虫攻击等。	网络中部署了华为防火墙。华为防火墙上设置入侵防范规则为 RPC 扫描、HTTP 扫描、PDF 文件格式检测、SSH 登录尝试、邮件协议的登录尝试等。华为规则库实时更新，应用程序和威胁最新一次更新时间为 2 月 14 日.	3

A.2.2 交换机

A.2.2.1 一平面实时交换机 H3C S3600V2 Series

测评对象	安全控制点	测评指标	结果记录	符合程度
一平面实时交	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功	网络边界为路由器，路由器为电力专用VPN通道进行通信，	5

测评对象	安全控制点	测评指标	结果记录	符合程度
换机 H3C S3600V 2 Series		能。	已启用访问控制功能。	
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN等访问权限的用户数量。	只有一个用户名为：huawei的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的	用户行为通过珠海鸿瑞（HR	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。交换机共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	交换机只设置了一个帐户，该账户权限仅运维商和厂站安全主管访问。其余人员没有网络设备的访问权限。	3
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为10位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间30分钟，非法登录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用SNMP服务，应采用安全性增强版本；并应设定	交换机仅开启需要的网络通信端口，（例如电力104协议端口和电力102 协议端口。）关闭了不需要的网络服务和	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		复杂的Community控制字段，不使用Public、Private等默认字段。	端口。	

A.2.2.2 二平面实时交换机 H3C S3600V2 Series

测评对象	安全控制点	测评指标	结果记录	符合程度
二平面实时交换机 H3C S3600V2 Series	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用VPN通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN等访	只有一个用户名为：huawei的用	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		问权限的用户数量。	户，无拨号访问需求。	
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。交换机共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	交换机只设置了一个帐户，该账户权限仅运维商和厂站安全主管访问。其余人员没有网络设备的访问权限。	3
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为10位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功	登陆超时时间30分钟，非法登	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用SNMP服务，应采用安全性增强版本；并应设定复杂的Community控制字段，不使用Public、Private等默认字段。	交换机仅开启需要的网络通信端口，（例如电力104协议端口和电力102 协议端口。）关闭了不需要的网络服务和端口。	5

A.2.2.3 二平面非实时交换机 H3C S3600V2 Series

测评对象	安全控制点	测评指标	结果记录	符合程度
二平面非实时交换机H3C S3600V2 Series	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用VPN通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d) 应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		网通信。	电力公司审核后接入电力调度网。	
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN等访问权限的用户数量。	只有一个用户名为：huawei的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。交换机共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；	交换机只设置了一个帐户，该账户权限仅运维商和厂站安	3

测评对象	安全控制点	测评指标	结果记录	符合程度
		禁止多个人员共用一个账号。	全主管访问。其余人员没有网络设备的访问权限。	
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为10位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间30分钟，非法登录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用SNMP服务，应采用安全性增强版本；并应设定复杂的Community控制字段， 不使用Public、Private等默认字段。	交换机仅开启需要的网络通信端口，（例如电力104协议端口和电力102 协议端口。）关闭了不需要的网络服务和端口。	5

A.2.2.4 二平面非实时交换机 东土科技 SICOM3024P

测评对象	安全控制点	测评指标	结果记录	符合程度
二平面非实时交换机东土科技SICOM 3024P	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用VPN通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问	生产控制大区的综合自动化	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN 等访问权限的用户数量。	只有一个用户名为：huawei的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			放、中断、下载），其中可查看对该设备的所有操作过程。	
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。交换机共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	交换机只设置了一个帐户，该账户权限仅运维商和厂站安全主管访问。其余人员没有网络设备的访问权限。	3
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为10位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间30分钟，非法登录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用SNMP服务，应采用安全性增强版本；并应设定复杂的Community控制字段，不使用Public、Private等默认字段。	交换机仅开启需要的网络通信端口，（例如电力104协议端口和电力102 协议端口。）关闭了不需要的网络服务和端口。	5

A.2.2.5 内网交换机 东土科技 SICOM3024P

测评对象	安全控制点	测评指标	结果记录	符合程度
内网交换机东土科技SICOM 3024P	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用VPN通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN等访问权限的用户数量。	只有一个用户名为：huawei的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		日志记录。		
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。交换机共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	交换机只设置了一个帐户，该账户权限仅运维商和厂站安全主管访问。其余人员没有网络设备的访问权限。	3
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为10位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间30分钟，非法登录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。	交换机仅开启需要的网络通信端口，（例如电力104协议	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		如需使用SNMP服务，应采用安全性增强版本；并应设定复杂的Community控制字段，不使用Public、Private等默认字段。	端口和电力102 协议端口。）关闭了不需要的网络服务和端口。	

A.2.2.6 外网交换机 北京博维亚 WitNet_IAS3028A-24T-ADC 220/S

测评对象	安全控制点	测评指标	结果记录	符合程度
外网交换机北京博维亚WitNet_IAS3028A-24T-ADC220/S	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用VPN通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN	N/A 此项不适用，一般在防火墙上实现。	N/A

测评对象	安全控制点	测评指标	结果记录	符合程度
		等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。		
		f）应限制具有拨号、VPN 等访问权限的用户数量。	只有一个用户名为：huawei的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。交换机共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	交换机只设置了一个帐户，该账户权限仅运维商和厂站安全主管访问。其余人员没有网络设备的访问权限。	3
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是	当前口令长度为10位，由字母和数字组成，口令不定期更换。	3

测评对象	安全控制点	测评指标	结果记录	符合程度
		字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。		
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间30分钟，非法登录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用SNMP服务，应采用安全性增强版本；并应设定复杂的Community控制字段，不使用Public、Private等默认字段。	交换机仅开启需要的网络通信端口，（例如电力104协议端口和电力102 协议端口。）关闭了不需要的网络服务和端口。	5

A.2.3 路由器

A.2.3.1 一平面路由器 H3C MSR 36-40

测评对象	安全控制点	测评指标	结果记录	符合程度
一平面路由器H3C MSR 36-40	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用VPN通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		认证和访问控制等安全防护措施。	纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN 等访问权限的用户数量。	只有一个用户名为：huawei的用户，ip vpn-instance vpn_dh route-distinguisher 26200:4 vpn-target 26200:400 20000:400 export-extcommunity vpn-target 26200:400 20000:400 import-extcommunity开启VPN功能。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过查看 info-center loghost 62.xx.xx.3 facility local4 开启审计功能。	5
		b）审计记录应包括事件的日期和时间、用户、事件类	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		型、事件是否成功及其他与审计相关的信息。	置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。路由器共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	交换机只设置了一个帐户，该账户权限仅运维商和厂站安全主管访问。其余人员没有网络设备的访问权限。	3
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为10位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间30分钟，非法登录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用SNMP服务，应采用安全性增强版本；并应设定复杂的Community控制字段，	交换机仅开启需要的网络通信端口，（例如电力104协议端口和电力102 协议端口。）关闭了不需要的网络服务和端口。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		不使用Public、Private等默认字段。		

A.2.3.2 二平面路由器 H3C MSR 36-40

测评对象	安全控制点	测评指标	结果记录	符合程度
二平面路由器 H3C MSR 36-40	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用VPN通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d) 应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e) 应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f)应限制具有拨号、VPN 等访问权限的用户数量。	只有一个用户名为：huawei的用户，ip vpn-instance vpn_dh	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			route-distinguisher 26200:4 vpn-target 26200:400 20000:400 export-extcommunity vpn-target 26200:400 20000:400 import-extcommunity开启VPN功能。	
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过查看 info-center loghost 62.xx.xx.3 facility local4 开启审计功能。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	交换机采用“默认用户名+密码”的方式进行身份鉴别。路由器共有一个用户：admin、已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有管理员用户，但没有对登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	交换机只设置了一个帐户，该账户权限仅运维商和厂站安全主管访问。其余人员没有网络设备的访问权限。	3
		d）身份鉴别信息应不易被冒	当前口令长度为10位，由字母	3

测评对象	安全控制点	测评指标	结果记录	符合程度
		用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	和数字组成，口令不定期更换。	
		e) 应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间30分钟，非法登录次数3次，登陆超时锁定10分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	设备使用telnet方式进行远程管理。	0
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用SNMP服务，应采用安全性增强版本；并应设定复杂的Community控制字段， 不使用Public、Private等默认字段。	交换机仅开启需要的网络通信端口，（例如电力104协议端口和电力102 协议端口。）关闭了不需要的网络服务和端口。	5

A.2.4 防火墙

A.2.4.1 外网防火墙 华为 Secoway USG2000

测评对象	安全控制点	测评指标	结果记录	符合程度
外网防火墙 华为 Secoway	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	防火墙启用了访问控制功能，采用 ACL 的方式进行访问控制 Access-group database_access_in in interface Database128。	5
		b)访问控制设备应能根据会	防火墙启用了访问控制功能，	5

测评对象	安全控制点	测评指标	结果记录	符合程度
USG2000		话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	采用 ACL 的方式进行访问控制 Access-group database_access_in in interface Database128，控制力度为端口级。	
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	在防火墙等网络控制设备中进行配置访问控制策略，粒度达到了单个用户。	5
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可，由电力公司提供地址范围及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	只有一个用户名为：huawei 的用户，无拨号访问需求。	5
		f）应限制具有拨号、VPN 等访问权限的用户数量。	只有一个用户名为：huawei 的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	通过网络安全监测装置进审计，用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备 IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	采用“默认用户名+密码”的方式进行身份鉴别。共有 1 个用户： admin，已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有对防火墙管理员的登录地址进行限制。限制地址是 10.0.3.91/32 IP 地址。	5
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	防火墙只设置了一个帐户，admin。	5
		d)身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度不小于 8 位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间 30 分钟，非法登录次数 3 次，登陆超时锁定 10 分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	防火墙直接通过 console 口进行登录，无远程登录功能。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等默认字段。	防火墙仅开启需要的网通信端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

A.2.4.3 内网防火墙 华为 Secoway USG2000

测评对象	安全控制点	测评指标	结果记录	符合程度
内网防火墙 华为 Secoway USG2000	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	防火墙启用了访问控制功能，采用 ACL 的方式进行访问控制 Access-group database_access_in in interface Database128。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	防火墙启用了访问控制功能，采用 ACL 的方式进行访问控制 Access-group database_access_in in interface Database128，控制力度为端口级。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	在防火墙等网络控制设备中进行配置访问控制策略，粒度达到了单个用户。	5
		d) 应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可，由电力公司提供地址范围及通讯端口，经电力公司审核后接入电力调度网。	5
		e) 应按用户和系统之间的允	只有一个用户名为：huawei 的	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	用户，无拨号访问需求。	
		f) 应限制具有拨号、VPN 等访问权限的用户数量。	只有一个用户名为：huawei 的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	通过网络安全监测装置进审计，用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备 IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	采用“默认用户名+密码”的方式进行身份鉴别。共有 1 个用户： admin，已按密码策略修改默认用户口令。	5
		b）应对网络设备的管理员登录地址进行限制。	有对防火墙管理员的登录地址进行限制。限制地址是 10.0.3.91/32 IP 地址。	5
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁	防火墙只设置了一个帐户，admin。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		止多个人员共用一个账号。		
		d)身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度不小于 8 位，由字母和数字组成，口令不定期更换。	3
		e) 应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间 30 分钟，非法登录次数 3 次，登陆超时锁定 10 分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	防火墙直接通过 console 口进行登录，无远程登录功能。	5
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等默认字段。	防火墙仅开启需要的网通信端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

A.2.5 加密装置

A.2.5.1 一平面省调实时纵向加密装置 兴唐 SJW07-A

测评对象	安全控制点	测评指标	结果记录	符合程度
一平面省调实时纵向加密	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用 VPN 通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，	访问控制功能在电力专线的纵向加密装置上设置。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		控制粒度为端口级。		
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d) 应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e) 应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f) 应限制具有拨号、VPN 等访问权限的用户数量。	纵向加密只有一个用户名为：admin 的用户，无拨号访问需求。	5
	安全审计(G2)	a) 应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b) 审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	通过网络安全监测装置进行审计，包括：等级、时间、类型、事件开始时间、设备名称、设备 IP、厂商名称、设备类型、	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			重复次数、描述。	
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	纵向加密采用 SM2 类型证书，通过专用客户端进行登录，登录验证方式为用户名+密码方式，需通过管理口进行登录，没有开启网口登录功能。	5
		b）应对网络设备的管理员登录地址进行限制。	没有对管理员登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	只有一个系统管理员账户，需客户端进行登录，只有安全负责人知道登录方式。	5
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为8 位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间 30 分钟，非法登录次数 3 次，登陆超时锁定 10 分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	纵向加密未开启远程管理。	5
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等默认字段。	端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

A.2.5.2 一平面地调实时纵向加密装置 兴唐 SJW07-A

测评对象	安全控制点	测评指标	结果记录	符合程度
一平面地调实时纵向加密装置 兴唐SJW07-A	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用 VPN 通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN 等访问权限的用户数量。	纵向加密只有一个用户名为：admin 的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、	通过网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		网络流量、用户行为等进行日志记录。		
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	通过网络安全监测装置进行审计，包括：等级、时间、类型、事件开始时间、设备名称、设备 IP、厂商名称、设备类型、重复次数、描述。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	纵向加密采用 SM2 类型证书，通过专用客户端进行登录，登录验证方式为用户名+密码方式，需通过管理口进行登录，没有开启网口登录功能。	5
		b）应对网络设备的管理员登录地址进行限制。	没有对管理员登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	只有一个系统管理员账户，需客户端进行登录，只有安全负责人知道登录方式。	5
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为8 位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间 30 分钟，非法登录次数 3 次，登陆超时锁定 10 分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	纵向加密未开启远程管理。	5
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等	端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		默认字段。		

A.2.5.3 二平面非实时纵向加密装置 兴唐 SJW07-A

测评对象	安全控制点	测评指标	结果记录	符合程度
二平面非实时纵向加密装置兴唐SJW07-A	访问控制(G2)	a）应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用 VPN 通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c）生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f) 应限制具有拨号、VPN 等访问权限的用户数量。	纵向加密只有一个用户名为：admin 的用户，无拨号访问需求。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	通过网络安全监测装置进行审计，包括：等级、时间、类型、事件开始时间、设备名称、设备 IP、厂商名称、设备类型、重复次数、描述。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	纵向加密采用 SM2 类型证书，通过专用客户端进行登录，登录验证方式为用户名+密码方式，需通过管理口进行登录，没有开启网口登录功能。	5
		b）应对网络设备的管理员登录地址进行限制。	没有对管理员登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	只有一个系统管理员账户，需客户端进行登录，只有安全负责人知道登录方式。	5
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为8 位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间 30 分钟，非法登录次数 3 次，登陆超时锁定 10 分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被	纵向加密未开启远程管理。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		窃听。		
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等默认字段。	端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

A.2.6 反向隔离装置 南京博思特 Stone Wall-2000

测评对象	安全控制点	测评指标	结果记录	符合程度
反向隔离装置南京博思特 Stone Wall-2000	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用 VPN 通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c) 生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d) 应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e) 应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒	N/A 此项不适用，一般在防火墙上实现。	N/A

测评对象	安全控制点	测评指标	结果记录	符合程度
		度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。		
		f）应限制具有拨号、VPN 等访问权限的用户数量。	只有一个用户名为：admin 的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	反向隔离没有开启安全审计功能。	0
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	没有开启审计功能。	0
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	反向隔离采用专用客户端进行登录，登录验证方式为用户名+密码方式，需通过管理口进行登录，没有开启网口登录功能。	0
		b）应对网络设备的管理员登录地址进行限制。	没有对管理员登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	只有一个系统管理员账户，需客户端进行登录，只有安全负责人知道登录方式。	5
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为 8 位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制	反向隔离默认登录失败次数为 3 次，登录连接超时为 30	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		非法登录次数和当网络登录连接超时自动退出等措施。	分钟。	
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	反向隔离未开启远程管理。	5
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等默认字段。	端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

A.2.7 网安监测装置

A.2.7.1 控制区网安监测装置 珠海鸿瑞 HR CRPM-3000

测评对象	安全控制点	测评指标	结果记录	符合程度
控制区网安监测装置 珠海鸿瑞 HR CRPM-3000	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用 VPN 通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c) 生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	5
		d)应该采用严格的接入控制措施，保证业务系统接入的	采用严格的接入控制措施，由电力公司提供接入电力调度	5

		可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f）应限制具有拨号、VPN 等访问权限的用户数量。	网络安全监测只有一个用户名为：huawei 的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防护(G2)	a）应对登录网络设备的用户进行身份鉴别。	网络安全监测采用专用客户端进行登录，登录验证方式为插入 U 盾验证后用户名+密码方式，需通过管理口进行登录，没有开启网口登录功能。	5
		b）应对网络设备的管理员登录地址进行限制。	没有对管理员登录地址进行限制。	0
		c) 网络设备标识应唯一；同一	只有一个系统管理员账户，需	5

		网络设备的用户标识应唯一；禁止多个人员共用一个账号。	客户端进行登录，只有安全负责人知道登录方式。	
		d) 身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为 8 位，由字母和数字组成，口令不定期更换。	3
		e) 应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间 30 分钟，非法登录次数 3 次，登陆超时锁定 10 分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	网络安全监测未开启远程管理。	5
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等默认字段。	端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

A.2.7.2 非控制区网安监测装置 珠海鸿瑞 HR CRPM-3000

测评对象	安全控制点	测评指标	结果记录	符合程度
非控制区网安监测装置珠海鸿瑞 HR CRPM-3000	访问控制(G2)	a) 应在网络边界部署访问控制设备，启用访问控制功能。	网络边界为路由器，路由器为电力专用 VPN 通道进行通信，已启用访问控制功能。	5
		b)访问控制设备应能根据会话状态信息为数据流提供明确的允许/拒绝访问的能力，控制粒度为端口级。	访问控制功能在电力专线的纵向加密装置上设置。	5
		c) 生产控制大区的拨号访问服务，服务器和客户端均应使用经安全加固的达到国家	生产控制大区的综合自动化服务器和客户端均配置了主机加固软件，操作系统达到国	5

		二级等级保护要求的操作系统，并采取加密、数字证书认证和访问控制等安全防护措施。	家二级等级保护要求，采取了u-key加密和数字证书双认证的纵向加密设备保障传送的电力遥控、遥信、遥测等信息在电力专线传送过程中的保密性。	
		d）应该采用严格的接入控制措施，保证业务系统接入的可信性。经过授权的节点允许接入电力调度数据网，进行广域网通信。	采用严格的接入控制措施，由电力公司提供接入电力调度网许可。由电力公司分配了唯一的 IP 地址及通讯端口，经电力公司审核后接入电力调度网。	5
		e）应按用户和系统之间的允许访问规则，边界的网络控制设备决定允许或拒绝用户对受控系统进行资源访问，控制粒度为单个用户。以拨号或 VPN 等方式接入网络的，应采用强认证方式，并对用户访问权限进行严格限制。	N/A 此项不适用，一般在防火墙上实现。	N/A
		f)应限制具有拨号、VPN 等访问权限的用户数量。	网络安全监测只有一个用户名为：huawei 的用户，无拨号访问需求。	5
	安全审计(G2)	a）应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。应在生产控制大区应部署专用审计系统，或启用设备或系统审计功能，应对网络系统中的网络设备运行状况、网络流量、用户行为等进行日志记录。	通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b）审计记录应包括事件的日期和时间、用户、事件类型、事件是否成功及其他与审计相关的信息。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
	网络设备防	a）应对登录网络设备的用	网络安全监测采用专用客户	5

	护(G2)	户进行身份鉴别。	端进行登录，登录验证方式为插入 U 盾验证后用户名+密码方式，需通过管理口进行登录，没有开启网口登录功能。	
		b）应对网络设备的管理员登录地址进行限制。	没有对管理员登录地址进行限制。	0
		c）网络设备标识应唯一；同一网络设备的用户标识应唯一；禁止多个人员共用一个账号。	只有一个系统管理员账户，需客户端进行登录，只有安全负责人知道登录方式。	5
		d）身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应修改默认用户和口令，不得使用缺省口令，口令长度不得小于 8 位，要求是字母和数字或特殊字符的混合并不得与用户名相同，口令应定期更换，并加密存储。	当前口令长度为 8 位，由字母和数字组成，口令不定期更换。	3
		e）应具有登录失败处理功能，可采取结束会话、限制非法登录次数和当网络登录连接超时自动退出等措施。	登陆超时时间 30 分钟，非法登录次数 3 次，登陆超时锁定 10 分钟，解锁方式为自动解锁。	5
		f)当对网络设备进行远程管理时，采取必要措施防止鉴别信息在网络传输过程中被窃听。	网络安全监测未开启远程管理。	5
		g)应封闭不需要的网络端口，关闭不需要的网络服务。如需使用 SNMP 服务，应采用安全性增强版本；并应设定复杂的 Community 控制字段，不使用 Public、Private 等默认字段。	端口和服务（例如电力 104 协议端口和电力 102 协议端口），关闭了不需要的网络服务和端口。	5

A.3 主机安全

A.3.1 光功率预测服务器

测评对象	安全控制点	测评指标	结果记录	符合程度

光功率预测服务器	身份鉴别	a) 应提供专用的登录控制模块对登录用户进行身份标识和鉴别。	登录服务器需要输入“用户名+密码”对登录用户进行身份鉴别。服务器密码保存在 KeePass 软件中，密文存储， 登录 KeePass 需要用户名/口令。登录数据库采用用户名/口令进行身份鉴别。	5
		b) 操作系统和数据库系统管理用户身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。口令长度不得小于8 位，	1、操作系统采用默认密码策略，如下： PASS_MAX_DAYS 99999 PASS_MIN_DAYS 0	3

测评对象	安全控制点	测评指标	结果记录	符合程度
		且为字母、数字或特殊字符的混合组合，用户名和口令禁止相同。	PASS_MIN_LEN 5 PASS_WARN_AGE 7 ENCRYPT_METHOD SHA512 2、当前密码长度为 10 位，包含英文、数字和特殊字符。 在配置文件/pam.d/passwd 配置 PASS_MIN_LEN=12 ，lcredit=-1,ucredit=-1,ocredit=-1,dcredit=-1; 数据库系统在VERIFY_FUNCTION=JS 函数里设置口令复杂度，长度至少 13 位，过滤弱密码，密码由数字、字母、特殊字符组成。	
		c) 应启用登录失败处理功能，可采取结束会话、限制非法登录次数和自动退出等措施；限制同一用户连续失败登录次数。	操作系统采用默认策略，最大登录失败重试次数是 3 次；/etc/pam.d/system-auth 和 password-auth 文件中 retry=3。	5
		d) 当对服务器进行远程管理时，应采取必要措施，防止鉴别信息在网络传输过程中被窃听。	1、未开启 telnet 服务。 2、系统启用了 SSH 服务，能够防止鉴别信息在网络传输过程中被窃听。	5
		e) 应为操作系统和数据库系统的不同用户分配不同的用户名，确保用户名具有唯一性。	操作系统无同名用户，用户名具备唯一性，root 帐户 UID 是 0。 数据库具有 SYS、System、系统用户账号与业务用户账号，操作系统具有 root、oracle 账号为不同用户分配不同用户名，用户名唯一，无重复。	5
	访问控制	a) 应启用访问控制功能，依据安全策略控制用户对资源的访问。	操作系统管理员对重要系统文件有读、查看、执行权限；普通用户只有读、查看权限。只针对 24 网段全部端口开放，其他网段无法访问，无共享目录	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		a) 应根据管理用户的角色分配权限，实现管理用户的权限分离，仅授予管理用户所需的最小权限。	除 root 帐户外，建立了一个普通（app）管理账户，仅授予用户所需的最小权限，实现管理用户的权限分离。更改权限时，需走流程审批，领导审批方可通过。	5
		b) 应严格限制默认账户的访问权限，重命名系统默认账户，并修改这些账户的默认口令； 应及时删除多余的、过期的账户，避免共享账户的存在。	1、操作系统中存在默认帐户，但修改了默认口令。 2、操作系统不存在过期、多余的帐户。 且根据 ISO 9001 制定内部详细制度，每季度自查用户，权限复查；人员离职时一旦审批业务用户锁定。	5
	安全审计	a)审计范围应覆盖到服务器上的每个操作系统用户和数据库用户；系统不支持该要求的，应以系统运行安全和效率为前提，采用第三方安全审计产品实现审计要求。	珠海鸿瑞（HR CRPM-3000）网络安全监测装置可以查看审计记录，审计记录用户的操作行为，可以查看用户操作的命令、用户实时操作、回放用户操作、中断用户操作、下载命令。	5
		b)审计内容应包括重要用户行为、系统资源的异常使用和重要系统命令的使用等系统内重要的安全相关事件。审计内容至少包括：用户的添加和删除、审计功能的启动和关闭、审计策略的调整、权限变更、系统资源的异常使用、重要的系统操作（如用户登录、退出）等。	珠海鸿瑞（HR CRPM-3000）网络安全监测装置审计记录用户的操作行为，可以查看用户操作的命令、用户实时的操作、回放用户操作行为、中断用户操作、下载操作文件，目前网络安全监测装置一直保存审计记录。	5
		c) 审计记录应包括事件的日期、时间、类型、主体标识、客体标识和结果等。	通过网络安全监测装置进行审计，包括：状态、协议、开始时间、结束时间、办公网 IP、用户、设备、系统账号、设备 IP 文件大小、命令数。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		d) 应保护审计记录，避免受到未预期的删除、修改或覆盖等。	无法对网络安全监测装置内记录进行删除，现场人员无设备操作权限，数据本地留存时长为 1 个月。	5
	入侵防范	a) 操作系统应遵循最小安装的原则，仅安装必要的组件和应用程序，并通过设置升级服务器等方式保持系统补丁及时得到更新，补丁安装前应进行安全性和兼容性测试。	1、操作系统的版本为：Red Hat Enterprise Linux Server release 7.4 (Maipo)，遵循最小安装原则。 2、内核版本为：Linux scadad2 3.10.0-693.el7.x86_64。 3、监听端口为： 111、53、22 631、5432 等。 4、经核查，系统补丁未及时得到更新。	3
	恶意代码防范	a)应在本机安装防恶意代码软件或独立部署恶意代码防护设备，并及时更新防恶意代码软件版本和恶意代码库。	服务器未安装防病毒软件。	0
		b) 应支持防恶意代码的统一管理。	服务器未安装防病毒软件。	0
	资源控制	a) 应通过设定终端接入方式、网络地址范围等条件限制终端登录。	对网络地址范围进行限制，只允许在特定终端进行登录操作。设置超时退出时间 3600 秒	5
		b) 应根据安全策略设置登录终端的操作超时锁定。	操作系统未设置登录超时锁定功能。此服务器为监控服务器 24 小时需要监控，且由专人进行管理。	3
		c) 应限制单个用户对系统资源的最大或最小使用限度。	对系统进程数和打开文件数进程限制。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		d) 应关闭或拆除主机的软盘驱动、光盘驱动、USB 接口、串行口等，确需保留的必须通过安全管理平台实施严格管理。	未关闭或拆除主机的软盘驱动、光盘驱动、USB 接口等，机箱放置在有锁柜中，钥匙由专人管理。	5

A.3.2 光功率气象服务器

测评对象	安全控制点	测评指标	结果记录	符合程度
光功率气象服务器	身份鉴别	a) 应提供专用的登录控制模块对登录用户进行身份标识和鉴别。	登录服务器需要输入“用户名+密码”对登录用户进行身份鉴别。服务器密码保存在 KeePass 软件中，密文存储， 登录 KeePass 需要用户名/口令。登录数据库采用用户名/口令进行身份鉴别。	5
		b) 操作系统和数据库系统管理用户身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。口令长度不得小于8 位，且为字母、数字或特殊字符的混合组合，用户名和口令禁止相同。	1、操作系统采用默认密码策略，如下： PASS_MAX_DAYS 99999 PASS_MIN_DAYS 0 PASS_MIN_LEN 5 PASS_WARN_AGE 7 ENCRYPT_METHOD SHA512 2、当前密码长度为 10 位，包含英文、数字和特殊字符。 在配置文件/pam.d/passwd 配置 PASS_MIN_LEN=12 ，lcredit=-1,ucredit=-1,ocredit=-1,dcredit=-1; 数据库系统在VERIFY_FUNCTION=JS 函数里设置口令复杂度，长度至少 13 位，过滤弱密码，密码由数字、字母、特殊字符组成。	3

测评对象	安全控制点	测评指标	结果记录	符合程度
		c) 应启用登录失败处理功能，可采取结束会话、限制非法登录次数和自动退出等措施；限制同一用户连续失败登录次数。	操作系统采用默认策略，最大登录失败重试次数是 3 次；/etc/pam.d/system-auth 和 password-auth 文件中 retry=3。	5
		d) 当对服务器进行远程管理时，应采取必要措施，防止鉴别信息在网络传输过程中被窃听。	1、未开启 telnet 服务。 2、系统启用了 SSH 服务，能够防止鉴别信息在网络传输过程中被窃听。	5
		e) 应为操作系统和数据库系统的不同用户分配不同的用户名，确保用户名具有唯一性。	操作系统无同名用户，用户名具备唯一性，root 帐户 UID 是 0。 数据库具有 SYS、System、系统用户账号与业务用户账号，操作系统具有 root、oracle 账号，为不同用户分配不同用户名，用户名唯一，无重复。	5
	访问控制	a) 应启用访问控制功能，依据安全策略控制用户对资源的访问。	操作系统管理员对重要系统文件有读、查看、执行权限；普通用户只有读、查看权限。只针对 24 网段全部端口开放，其他网段无法访问，无共享目录。	5
		b) 应根据管理用户的角色分配权限，实现管理用户的权限分离，仅授予管理用户所需的最小权限。	除 root 帐户外，建立了一个普通（app）管理账户，仅授予用户所需的最小权限，实现管理用户的权限分离。更改权限时，需走流程审批，领导审批方可通过。	5
		c) 应严格限制默认账户的访问权限，重命名系统默认账户，并修改这些账户的默认口令； 应及时删除多余的、过期的账户，避免共享账户的存在。	1、操作系统中存在默认帐户，但修改了默认口令。 2、操作系统不存在过期、多余的帐户。 且根据 ISO 9001 制定内部详细制度，每季度自查用户，权限复查；人员离职时一旦审批业	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			务用户锁定。	
	安全审计	a)审计范围应覆盖到服务器上的每个操作系统用户和数据库用户；系统不支持该要求的，应以系统运行安全和效率为前提，采用第三方安全审计产品实现审计要求。	珠海鸿瑞（HR CRPM-3000）网络安全监测装置可以查看审计记录，审计记录用户的操作行为，可以查看用户操作的命令用户实时操作、回放用户操作中断用户操作、下载命令。	5
		b) 审计内容应包括重要用户行为、系统资源的异常使用和重要系统命令的使用等系统内重要的安全相关事件。审计内容至少包括：用户的添加和删除、审计功能的启动和关闭、审计策略的调整、权限变更、系统资源的异常使用、重要的系统操作（如用户登录、退出）等；。	珠海鸿瑞（HR CRPM-3000）网络安全监测装置审计记录用户的操作行为，可以查看用户操作的命令、用户实时的操作、回放用户操作行为、中断用户操作、下载操作文件，目前网络安全监测装置一直保存审计记录。	5
		c) 审计记录应包括事件的日期、时间、类型、主体标识、客体标识和结果等。	通过网络安全监测装置进行审计，包括：状态、协议、开始时间、结束时间、办公网 IP、用户、设备、系统账号、设备 IP 文件大小、命令数。	5
		d) 应保护审计记录，避免受到未预期的删除、修改或覆盖等。	无法对网络安全监测装置内记录进行删除，现场人员无设备操作权限，数据本地留存时长为 1 个月。	5
	入侵防范	a) 操作系统应遵循最小安装的原则，仅安装必要的组件和应用程序，并通过设置升级服务器等方式保持系统补丁及时得到更新，补丁安装前应进行安全性和兼容性测试。	1、操作系统的版本为：Red Hat Enterprise Linux Server release 7.4 (Maipo)，遵循最小安装原则。 2、内核版本为：Linux scadad2 3.10.0-693.el7.x86_64。 3、监听端口为： 111、53、22	3

测评对象	安全控制点	测评指标	结果记录	符合程度
			631、5432 等。 4、经核查，系统补丁未及时得到更新。	
	恶意代码防范	a)应在本机安装防恶意代码软件或独立部署恶意代码防护设备，并及时更新防恶意代码软件版本和恶意代码库。	服务器未安装防病毒软件。	0
		b) 应支持防恶意代码的统一管理。	服务器未安装防病毒软件。	0
	资源控制	a) 应通过设定终端接入方式、网络地址范围等条件限制终端登录。	对网络地址范围进行限制，只允许在特定终端进行登录操作。设置超时退出时间 3600 秒	5
		b) 应根据安全策略设置登录终端的操作超时锁定。	操作系统未设置登录超时锁定功能。此服务器为监控服务器 24 小时需要监控，且由专人进行管理。	3
		c) 应限制单个用户对系统资源的最大或最小使用限度。	对系统进程数和打开文件数进程限制。	5
		d) 应关闭或拆除主机的软盘驱动、光盘驱动、USB 接口、串行口等，确需保留的必须通过安全管理平台实施严格管理。	未关闭或拆除主机的软盘驱动、光盘驱动、USB 接口等，机箱放置在有锁柜中，钥匙由专人管理。	5

A.3.3 气象服务器

测评对象	安全控制点	测评指标	结果记录	符合程度

测评对象	安全控制点	测评指标	结果记录	符合程度
气象服务器	身份鉴别	a) 应提供专用的登录控制模块对登录用户进行身份标识和鉴别。	1、登录操作系统需要输入“用户名+密码”对登录用户进行身份鉴别。 2、勾选了“要使用本机，用户必须输入用户名和密码”。	5
		b) 操作系统和数据库系统管理用户身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。口令长度不得小于8位，且为字母、数字或特殊字符的混合组合，用户名和口令禁止相同。	1、当前密码长度大为 10 位，包含英文、数字和特殊字符。 2、操作系统的密码策略如下： 1） 密码必须符合复杂性要求：已禁用； 2） 密码长度最小值：0个字符； 3） 密码最长使用期限：42 天； 4） 密码最短使用期限：0 天； 5） 强制密码历史：0 个记住的密码； 6） 用可还原的加密来存储密码：已禁用。	3
		c) 应启用登录失败处理功能，可采取结束会话、限制非法登录次数和自动退出等措施；限制同一用户连续失败登录次数。	1、操作系统的帐户锁定策略如下： 1） 复位帐户锁定计数器：不适用； 2） 帐户锁定时间：不适用； 3） 帐户锁定阈值：0 次无效登录。 2、经询问，系统连续登录 6 次锁定 3 分钟。	3
		d) 当对服务器进行远程管理时，应采取必要措施，防止鉴别信息在网络传输过程中被窃听。	采用远程管理桌面方式管理服务器，未启用Telnet 服务。	5
		e) 应为操作系统和数据库系统的不同用户分配不同的用户名，确保用户名具有唯一性。	操作系统只有一个管理账户进行登录，用户名具有唯一性。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
	访问控制	a) 应启用访问控制功能，依据安全策略控制用户对资源的访问。	操作系统仅建立了一个管理账户。	5
		b) 应根据管理用户的角色分配权限，实现管理用户的权限分离仅授予管理用户所需的最小权限。	操作系统仅建立了一个管理账户。	5
		c) 应严格限制默认账户的访问权限，重命名系统默认账户，并修改这些账户的默认口令； 应及时删除多余的、过期的账户避免共享账户的存在。	1、操作系统中存在默认帐户，但都已禁用。 2、操作系统中不存在多余、过期的帐户。	5
	安全审计	a)审计范围应覆盖到服务器上的每个操作系统用户和数据库用户；系统不支持该要求的，应以系统运行安全和效率为前提，采用第三方安全审计产品实现审计要求。	通过珠海鸿瑞（HR CRPM-3000网络安全监测装置对设备运行状况、网络流量、用户行为进行监控，并记录审计信息。	5
		b)审计内容应包括重要用户行为、系统资源的异常使用和重要系统命令的使用等系统内重要的安全相关事件。审计内容至少包括：用户的添加和删除、审计功能的启动和关闭、审计策略的调整、权限变更、系统资源的异常使用、重要的系统操作（如用户登录、退出）等。	用户行为通过珠海鸿瑞（HR CRPM-3000）网络安全监测装置进行审计，会话审计记录：协议、开始时间、结束时间、来自、用户、设备、系统账号、设备IP、文件大小（MB）、命令数、查看（命令、实时、回放、中断、下载），其中可查看对该设备的所有操作过程。	5
		c) 审计记录应包括事件的日期、时间、类型、主体标识、客体标识和结果等。	审计记录包括：安全日志、系统日志、应用程序日志。 1、安全日志包含类型、日期、时间、来源、分类、事件、用户和计算机信息。 2、应用程序日志和系统日志包括级别、日期和时间、来源、	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			分类、事件、用户和计算机等信息。	
		d) 应保护审计记录，避免受到未预期的删除、修改或覆盖等。	1、操作系统已禁用 Administrator 和 Guest 帐户。 2、只有 administrators 组用户可以“管理审核和安全日志”。	5
	入侵防范	a) 操作系统应遵循最小安装的原则，仅安装必要的组件和应用程序，并通过设置升级服务器等方式保持系统补丁及时得到更新，补丁安装前应进行安全性和兼容性测试。	1、操作系统版本是 Windows 7 Service Pack 1。 2、未遵循最小安装原则。 3、Windows 未开启自动更新。安装 1 个修补程序（KB2685811）。 4、服务器当前开启的监听端口为： 135、445 等。 5、默认共享为： ADMIN$、C$、D$ 、E$、IPC$（这是为管理用途共享的。无法设置共享权限和文件安全设置）。	2
	恶意代码防范	a)应在本机安装防恶意代码软件或独立部署恶意代码防护设备，并及时更新防恶意代码软件版本和恶意代码库。	安装 360 安全卫士查毒软件，病毒库更新日期：2018-6-20。版本 11.4.0.2003。	3
		b) 应支持防恶意代码的统一管理。	未对防恶意代码进行统一管理。	0
	资源控制	a) 应通过设定终端接入方式、网络地址范围等条件限制终端登录。	能够对网络地址范围进行限制，只允许在特定终端进行登录操作。	5
		b) 应根据安全策略设置登录终端的操作超时锁定。	1、未设置屏幕保护程序。 2、未配置“活动但空闲的远程桌面服务会话时间的限制”。	0
		c) 应限制单个用户对系统资源的最大或最小使用限度。	系统未对用户资源的使用进行限制，主机资源充足，能够满足当前的实际需要。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		d) 应关闭或拆除主机的软盘驱动、光盘驱动、USB 接口、串行口等，确需保留的必须通过安全管理平台实施严格管理。	未关闭或拆除主机的软盘驱动、光盘驱动、USB 接口等，机箱放置在有锁柜中，钥匙由专人管理。	5

A.4 应用安全

A.4.1 功率预测系统

测评对象	安全控制点	测评指标	结果记录	符合程度
功率预测系统	身份鉴别(S2)	a) 应提供专用的登录控制模块对登录用户进行身份标识和鉴别。	经检查登录界面，登录使用用户名+口令的登录方式进行身份标识和鉴别。	5
		b) 应用系统用户身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应提供用户身份标识唯一和鉴别信息复杂度检查功能，保证应用系统中不存在重复用户身份标识；用户在第一次登录系统时修改分发的初始口令，口令长度不得小于 8 位，且为字母、数字或特殊字符的混合组合，用户名和口令禁止相同；应用软件不得明文存储口令数据。	经访谈系统管理员，登录口令时查看密码长度为 8 位，符合 8 位标准，为字母+数字的混合方式，用户名和口令不相同。口令更新周期为三个月。	5
		c) 应提供登录失败处理功能可采取结束会话、限制非法登录次数和自动退出等措施。	经测试，用户名或密码输入错误，提示“用户名或密码错误”提供了登录失败处理功能。	5
		e) 应启用身份鉴别、用户身份标识唯一性检查、用户身份鉴别信息复杂度检查以及登录失败处理功能，并根据安全策	采取用户名+密码的方式进行登录，对用户身份进行鉴别，未设置密码复杂度策略，有登录失败处理功能，登陆失败提示密码	3

测评对象	安全控制点	测评指标	结果记录	符合程度
		略配置相关参数。	错误。	
	访问控制(S2)	a) 应提供访问控制功能，依据安全策略控制用户对文件、数据库表等客体的访问。	经查看系统用户，Admin 为超级管理员用户，此用户为超级用户权限，app 为登录客户端用户，只存在查看权限。	5
		b) 访问控制的覆盖范围应包括与资源访问相关的主体、客体及它们之间的操作。	经查看系统用户，Admin 为超级管理员用户，此用户为超级用户权限，app 为登录客户端用户，只存在查看权限。	5
		c) 应由授权主体配置访问控制策略，并严格限制默认帐户的访问权限。	经查看系统用户，Admin 为超级管理员用户，此用户为超级用户权限，app 为登录客户端用户，只存在查看权限。	5
		d) 应授予不同帐户为完成各自承担任务所需的最小权限，并在它们。之间形成相互制约的关系。	经查看系统用户，Admin 为超级管理员用户，此用户为超级用户权限，app 为登录客户端用户，只存在查看权限。	5
	安全审计(S2)	a) 应提供覆盖到每个用户的安全审计功能，对应用系统的用户登录、用户退出、增加用户、修改用户权限等重要安全事件进行审计。	经访谈系统管理员，电力监控系统没有审计功能。	0
		b) 应保证审计活动的完整性保证无法删除、修改或覆盖审计记录。	电力监控系统没有审计功能。	0
		c) 审计记录的内容至少应包括事件的日期、时间、发起者信息、类型、描述和结果等。	电力监控系统没有审计功能。	0
	通信完整性(S2)	a) 应采用校验码技术保证通信过程中数据的完整性。	经访谈系统管理员，系统为 C/S 架构，固定 IP 地址/端口进行通信。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
	通信保密性(S2)	a) 在通信双方建立连接之前，应用系统应利用密码技术进 行会话初始化验证。	系统为 C/S 架构，固定 IP 地址/端口进行通信，系统在通信双方建立之前，没有利用密码技术进行会话初始化验证。	0
		b) 应对通信过程中的整个报文或会话过程进行加密。	经访谈系统管理员，没有对通信过程中的用户口令、会话密钥等敏感信息字段进行加密。	0
	软件容错(S2)	a) 应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的数据格式或长度符合系统设定要求。	经访谈系统管理员，电力监控系统未提供数据有效性检验功能	0
		b) 在故障发生时，应用系统应能够继续提供一部分功能，确保能够实施必要的措施。	经访谈系统管理员，电力监控系统软件部分出错不会影响系统整体的运行。	5
	资源控制(S2)	a) 当应用系统的通信双方中的一方在一段时间内未作任何响应，另一方应能够自动结束会话。	电力监控系统需要每隔 15 分钟查看信息，不会自动结束会话	0
		b) 应能够对系统的最大并发会话连接数进行限制。	电力监控系统没有对系统的最大并发会话连接数进行限制。	0
		c) 应能够对单个帐户的多重并发会话进行限制。	电力监控系统业务峰值为单用户操作。没有对单个帐户的多重并发会话进行限制。	0

A.4.2 光功率预测系统

测评对象	安全控制点	测评指标	结果记录	符合程度
光功率预测系统	身份鉴别(S2)	a) 应提供专用的登录控制模块对登录用户进行身份标识和鉴别。	查看登录界面，登录系统使用用户名+口令的登录方式进行身份标识和鉴别。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 应用系统用户身份鉴别信息应不易被冒用，口令复杂度应满足要求并定期更换。应提供用户身份标识唯一和鉴别信息复杂度检查功能，保证应用系统中不存在重复用户身份标识；用户在第一次登录系统时修改分发的初始口令，口令长度不得小于 8 位，且为字母、数字或特殊字符的混合组合，用户名和口令禁止相同；应用软件不得明文存储口令数据。	经访谈系统管理员，登录口令时查看密码长度为 8 位，符合 8 位标准，为字母+数字的混合方式，用户名和口令不相同。	5
		c) 应提供登录失败处理功能可采取结束会话、限制非法登录次数和自动退出等措施。	光功率预测系统密码或用户名输入错误显示“用户名或密码错误”，没有自动退出功能。	3
		e) 应启用身份鉴别、用户身份标识唯一性检查、用户身份鉴别信息复杂度检查以及登录失败处理功能，并根据安全策略配置相关参数。	光功率预测系统只采用用户名和密码的登陆方式对用户进行身份鉴别，未设置密码复杂度策略，未提供失败处理功能。	0
	访问控制(S2)	a) 应提供访问控制功能，依据安全策略控制用户对文件、数据库表等客体的访问。	经查看系统用户，光功率预测系统用户分为管理员用户和值班员用户，值班员用户职能做查看工作。	5
		b) 访问控制的覆盖范围应包括与资源访问相关的主体、客体及它们之间的操作。	经查看系统用户，光功率预测系统用户分为管理员用户和值班员用户，值班员用户职能做查看工作。	5
		c) 应由授权主体配置访问控制策略，并严格限制默认帐户的访问权限。	经查看系统用户，光功率预测系统用户分为管理员用户和值班员用户，值班员用户职能做查看工作。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		d) 应授予不同帐户为完成各自承担任务所需的最小权限，并在它们之间形成相互制约的关系。	访谈系统管理员，光功率预测系统用户分为管理员用户和值班员用户，值班员用户职能做查看工作。	5
	安全审计(S2)	a) 应提供覆盖到每个用户的安全审计功能，对应用系统的用户登录、用户退出、增加用户、修改用户权限等重要安全事件进行审计。	访谈了安全管理员，光功率预测系统没有审计功能。	0
		b) 应保证审计活动的完整性保证无法删除、修改或覆盖审计记录。	光功率预测系统没有审计功能	0
		c) 审计记录的内容至少应包括事件的日期、时间、发起者信息、类型、描述和结果等。	光功率预测系统没有审计功能	0
	通信完整性(S2)	a) 应采用校验码技术保证通信过程中数据的完整性。	访谈了系统管理员，系统为 B/S 架构，固定 IP 地址、端口进行通信。	5
	通信保密性(S2)	a) 在通信双方建立连接之前应用系统应利用密码技术进行会话初始化验证。	访谈了系统管理员，系统为 B/S 架构，固定 IP 地址、端口进行通信，系统在通信双方建立之前，没有利用密码技术进行会话初始化验证。	0
		b) 应对通信过程中的整个报文或会话过程进行加密。	访谈了系统管理员，没有对通信过程中的用户口令、会话密钥等敏感信息字段进行加密。	0
	软件容错(S2)	a) 应提供数据有效性检验功能，保证通过人机接口输入或通过通信接口输入的数据格式或长度符合系统设定要求。	访谈了系统管理员，光功率预测系统未提供数据有效性检验功能。	0

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 在故障发生时，应用系统应能够继续提供一部分功能，确保能够实施必要的措施。	访谈了系统管理员，软件部分出错不会影响系统整体的运行。	5
	资源控制(S2)	a) 当应用系统的通信双方中的一方在一段时间内未作任何响应，另一方应能够自动结束会话。	光功率预测系统需要每隔 15 分钟查看信息，不会自动结束会话。	0
		b) 应能够对系统的最大并发会话连接数进行限制。	光功率预测系统没有对系统的最大并发会话连接数进行限制	0
		c) 应能够对单个帐户的多重并发会话进行限制。	光功率预测没有对单个帐户的多重并发会话进行限制。	0

A.5 数据安全

测评对象	安全控制点	测评指标	结果记录	符合程度
数据安全	数据完整性（S2）	a）应能够检测到鉴别信息和重要业务数据在传输过程中完整性受到破坏。	鉴别信息加密传输，业务数据通过专用VPN 通道交换系统定制的数据包进行传输，数据包完整性受到破坏时，进行重传。	5
	数据保密性（S2）	a) 应采用加密或其他保护措施实现鉴别信息的存储保密性。	鉴别信息通过纵向加密换设备加密传输，业务数据通过专用 VPN 通道数据交换系统定制的数据包进行传输。	5
	备份和恢复（A2）	a) 应对重要信息进行备份，并对备份介质定期进行可用性测试；	网络层面：网络层面配置信息由调度统一进行管理，配置详情存储调度和本地。 应用层面：经查看得知有定期数据备份，备份数据为应用平台存储电站监测数据，周期为 2 天，本地备份和异地备份。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 应提供关键网络设备、通信线路和数据处理系统的硬件冗余，保证系统的可用性。	系统采用一二平面双链路传输相同数据，分别传输省调和地调，若一条线路出现问题，可通过另一条链路读取数据。	5

A.6 安全管理制度

测评对象	安全控制点	测评指标	结果记录	符合程度
安全管理制度	管理制度	a)应按照“谁主管谁负责，谁运营谁负责”的原则，建立电力二次系统安全管理制度，制定信息安全工作的总体方针和安全策略，说明机构安全工作的总体目标、范围、原则和安全框架等，并将电力二次系统安全防护及其信息报送纳入日常安全生产管理体系，负责所辖范围内计算机及数据网络的安全管理。	查看《电力监控系统安全防护管理制度》、《电力监控系统安全防护岗位职责》文档。经查看《光伏发电站电力监控系统安全防护制度》，内容为制定服务器管理，岗位职责技术职责，账号权限，整体设计原则等。	5
		b)应对安全管理活动中重要的管理内容建立安全管理制度，主要包括：门禁管理、人员管理、权限管理、访问控制管理、安全防护系统的维护管理、常规设备及各系统的维护管理、恶意代码的防护管理、审计管理、数据及系统的备份管理、用户口令密钥及数字证书的管理、培训管理等。	经查看《电力监控系统运维管理规定》、《光伏发电站电力监控系统安全防护制度》内容覆盖福物理、网络、主机应用、数据、建设和管理等各层面。	5
		c)应对安全管理人员或操作人员执行的重要管理操作建立操作规程。	经查看《电力监控系统运维管理规定》覆盖管理人员或操作人员执行日常管理操作等内容的规定和办法，系统开发单位提供系统使用和维护手册，指	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			导管理、操作和维护人员进行规范操作。	
	制定和发布（G2）	a)应指定或授权专门的部门或人员负责安全管理制度的制定。	经访谈安全管理员，《光伏发电站电力监控系统安全防护制度》由厂站成员制定，安全管理员审核，厂站站长批准执行安全管理制度。有制度起草、逐级审核，最后由公司领导审批发布，有完整的制定和发布程序。	5
		b)应组织相关人员对制定的安全管理制度进行论证和审定。	经访谈安全管理员，厂站的安全管理制度起草、审核、并由厂站站长批准发布，但没有管理制度评审记录。	3
		c)应将安全管理制度以某种方式发布到相关人员手中。	经访谈安全管理员，制度通过会议的方式让公司成员集体参与听讲，，并形成会议纪要后让参会人员确认签字。纸质版文件通过厂站建立的通讯软件群进行下发。	5
	评审和修订（G2）	a）定期或在发生重大变更时对安全管理制度进行检查和审定，对存在不足或需要改进的安全管理制度进行修订。	经访谈安全管理员，安全管理制度的重大变更由站长批准后安全管理员进行检查和审定，但没有安全管理制度的评审记录。	3

A.7 安全管理机构

测评对象	安全控制点	测评指标	结果记录	符合程度
安全管理机构	岗位设置(G2)	a)应明确由主管安全生产的领导作为电力二次系统安全防护的主要责任人。	经查看《定西电力调度系统网络安全责任书》，场站制定了《光伏发电站电力监控系统安全防护岗位职责》和《	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			光伏发电站电力监控系统安全防护管理制度》，明确了安全主管的负责人和职责范围。	
		b)应设立安全主管、安全管理各个方面的负责人岗位，并定义各负责人的职责。	经查看《电力监控系统安全防护岗位职责》，场站根据电力公司要求设置了安全主管、安全专责、安全管理员岗位，并明确职责范围。	5
		c) 应设立系统管理员、网络管理员、安全管理员等岗位，并定义各个工作岗位的职责。	经访谈安全管理员，场站制定了《光伏发电站电力监控系统安全防护岗位职责》，设立并规定了系统管理员、安全管理员、网络管理员等岗位职责。	5
	人员配备（G2	a)应配备一定数量的系统管理员、网络管理员、安全管理员等。	经访谈安全管理员，场站制定了《光伏发电站电力监控系统安全防护岗位职责》，配备了安全主管 1 名、安全专责 3 名（包含系统管理员 1 名、安全管理员 1 名、网络管理员 1 名）。	5
		b) 安全管理员不能兼任网络管理员、系统管理员、数据库管理员等。	经访谈安全管理员，网络安全管理员由电站部门负责人兼任。没有配备专职人员。	0
	资金保障（G2	a) 应保障落实信息系统安全建设、运维及等级保护测评资金等。	经查看《电力监控系统运维管理规定》文档，由公司每年申请信息系统安全建设、运维及等级保护测评资金预算，由公司审批并发放经费。	5
		b) 系统建设资金筹措方案和年度系统维护经费应包括信息安全保障资金项目。	经访谈安全负责人，由公司每年申请信息系统安全建设、运维及等级保护测评资金预算，预算包括信息安全保障资金项目。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
	授权和审批	a)应根据各个部门和岗位的职责明确授权审批部门及批准人， 对系统投入运行、网络系统接入和重要资源的访问等关键活动进行审批。	经访谈安全主管及查看《电力监控系统安全防护岗位职责》重要活动进行审批，批准人是各方面负责人；对系统投入运行、网络系统接入和重要资源的访问等关键活动由网络安全专责负责审核，由安全主管批准执行。	5
		b)应针对关键活动建立审批流程，并由批准人签字确认。	经访谈安全主管，重要活动进行审批，批准人是各方面负责人；对系统投入运行、网络系统接入和重要资源的访问等关键活动由网络安全专责负责审核，由安全主管批准执行。	5
		c) 接入电力调度数据网络的节点、设备和应用系统，其接入技术方案和安全防护措施须经负责本级电力调度数据网络的调度机构核准。	经查看《系统变更控制方面的管理制度》文档，接入方案由厂站提供给电力调度，电力调度批准后给厂站许可并明确接入范围，最终由电力调度审核接入合格性。	5
	沟通与合作	a)应加强各类管理人员之间、组织内部机构之间以及信息安全职能部门内部的合作与沟通。	经访谈安全管理员及查看相关的会议记录得知，各类管理人员之间定期或不定期召开信息安全相关主题会议，并形成记录文档，参与人员现场签字确认，形成会议签到表。	5
		b)应加强与行业信息安全监管部门、公安机关、通信运营商银行及相关单位和部门的合作与沟通。	经访谈安全管理员，场站与电力公司、定西市公安局、定西市移动公司、各银行金融企业有沟通合作机制，参与系统建设方案等信息安全项目评审，并根据实际工作需要定期或不定期沟通指导配合相关工作。	5
	审核和检查	a)安全管理员应负责定期进行安全检查，检查内容包括系统日常运行、系统漏洞和数据备	经查看《系统监控、风险评估漏洞扫描方面的管理制度》，安全管理员定期检查系统日常	3

测评对象	安全控制点	测评指标	结果记录	符合程度
		份等情况。	运行和数据备份情况，形成备份日志，每隔两天进行异地备份。但没有进行漏洞扫描，未形成扫描日志。	

A.8 人员安全管理

测评对象	安全控制点	测评指标	结果记录	符合程度
人员安全管理	人员录用	a) 应指定或授权专门的部门或人员负责人员录用。	经访谈安全管理员及查看《人事管理制度》、人员聘用文档人员录用由上级单位行政人事部负责电站人员录用工作。	5
		b) 应规范人员录用过程，对被录用人员的身份、背景和专业资格等进行审查，对其所具有的技术技能进行考核。	经访谈安全管理员，查看《人事管理制度》以及录用人员的审查记录，人员录用由上级单位行政人事部负责电站人员录用工作，资质审核以及技术考核。	5
		c) 应与安全管理员、系统管理员、网络管理员等关键岗位的人员签署保密协议。	经访谈人事经理，被录用人员到电站工作前，进行培训后上岗并签署保密协议。明确保密范围、保密责任、违约责任、协议的有效期限和责任人的签字等内容。	5
	人员离岗	a) 应规范人员离岗过程，及时终止离岗员工的所有访问权限。	经访谈电站网络安全管理员，由电站人事经理负责离岗人员访问权限的终止和各类资产的收回。由上级单位行政人事部负责电站人员离岗工作并签署相关离职协议。严格规范人员离岗过程。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 应取回各种身份证件、钥匙、徽章等以及机构提供的软硬件设备。	经访谈电站网络安全管理员，由上级单位行政人事部负责电站人员离岗工作并签署相关离职协议。离岗人员交还身份证件、钥匙、徽章等以及公司提供的软硬件设备等。	5
		c) 只有在收回访问权限和各种证件、设备之后方可办理调离手续。	经访谈电站网络安全管理员，由上级单位行政人事部负责电站人员离岗工作并签署相关离岗协议。	5
	人员考核	a) 应定期对各个岗位的人员进行安全技能及安全认知的考核。	经查看《年度信息安全培训计划》，培训记录文档等，依据上级单位安排，由电站人员组织进行安全技能、安规和网络安全的考试，考试每月进行一次。	5
	安全意识教育和培训	a) 应对各类人员进行安全意识教育、岗位技能培训和相关安全技术培训。	经访谈人事经理，查看培训记录，定期进行安全意识教育会议培训，培训完之后进行考试，形成培训记录和考试记录。	5
		b) 应告知人员相关的安全责任和惩戒措施，并对违反违背安全策略和规定的人员进行惩戒。	经访谈人事经理，查看了《安全责任和惩戒通知书》，《年度信息安全培训计划》中明确了为保障发电站网络安全，电站工作人员的职责以及对违反安全策略和规定的人员进行惩戒。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		c) 应按照行业信息安全要求，制定安全教育和培训计划，对信息安全基础知识、岗位操作规程等进行的培训应至少每年举办一次。	经访谈人事经理，及查看《年度信息安全培训计划》，《年度信息安全培训计划》定期的对所有工作人员进行了 相关的培训，包括《对网络安全法的认识》、《中华人民共和国网络安全法法律责任》等安全教育、以及安全基础知识、岗位操作规程等。	5
	外部人员访问管理	a）应确保在外部人员访问受控区域前得到授权或审批，批准后由专人全程陪同或监督，并登记备案。	经查看《继电保护室人员出入登记表》，机房出入口有专人24 小时值守，来访人员都是经过站长批准，有专人陪同，并且签写《机房出入登记表》，包括日期、姓名、单位、事由电话等内容。专人陪同。	5

A.9 系统建设管理

测评对象	安全控制点	测评指标	结果记录	符合程度
系统建设管理	系统定级	a) 应明确信息系统的边界和安全保护等级。	经访谈安全管理员及查看《光伏电站监控系统信息安全等级保护定级报告》明确信息系统的边界和信息系统的安全保护等级。	5
		b) 应以书面的形式说明确定信息系统为某个安全保护等级的方法和理由。	经访谈安全管理员，以电力行业标准、地调、定级报告等相关文件为基础，参照《定级指南》确定信息系统安全保护等级，定级报告说明该系统为S2A2G2 的方法和理由。	5
		c) 应确保信息系统的定级结果经过行业信息安全主管部	经访谈安全管理员，该公司定级结果经过了定西市网安大	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		门批准，方可到公安机关备案。	队和地调的批准，根据电力行业定级要求，该电站为 110KV 变电站，定为二级。	
	安全方案设计	a) 应根据系统的安全保护等级选择基本安全措施，并依据电力二次系统安全防护要求和风险分析的结果补充和调整安全措施。	根据系统的安全保护等级选择基本安全措施，定级后完善策略、制度方面并调整安全措施。经访谈安全管理员，在系统建设和网络建设前期，厂商需向电站提供设计方案，在方案中必须要求厂商填写风险分析的结果，以及安全措施。	5
		b) 应以书面形式描述对系统的安全保护要求、策略和措施等内容，形成系统的安全方案。	经访谈安全管理员及查看信息系统建设的设计方案，方案中涉及系统的安全方案。	5
		c）应对安全方案进行细化，形成能指导安全系统建设、安全产品采购和使用的详细设计方案。	经访谈安全管理员，查看《项目实施管理制度》、《产品采购管理制度》文档及系统建设方案，方案中提供系统安全的建设。安全产品采购和使用根据国家电网要求，符合国家电网要求的安全产品。	5
		d）应组织相关部门和有关安全技术专家对安全设计方案的合理性和正确性进行论证和审定，重大项目应报行业信息安全主管部门进行信息安全专项审查批准。	经访谈安全管理员，查看了相关的论证记录，电站安全设计方案需经过厂站自行验收后，向调度及上级单位（甘肃省电力公司）报送并组织相关专家对方案进行了论证和审定。	5
	产品采购和使用	a) 应确保安全产品采购和使用符合国家的有关规定。	《IT 设备采购管理制度》中有安全产品采购和使用符合国家的有关规定。经访谈安全管理员及查看相关的产品技术手册，根据上级单位要求，安全产品采购使用符合国家的有关规定。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 应确保密码产品采购和使用符合国家密码主管部门的要求。	经查看纵向加密设备产品说明书，功率预测系统专用的密码产品（纵向加密）的采购和使用符合国家密码主管部门要求。	5
		c) 应指定或授权专门的部门负责产品的采购。	经访谈安全负责人，查看公司《产品采购管理制度》，电站向上级单位发送采购申请表申请，经同意后可进行采购。	5
		d) 接入电力二次系统生产控制大区中的安全产品，其功能、性能应获得国家或行业指定机构安全检测证明，其电磁兼容性还需有电力系统电磁兼容检测证明。	经访谈安全负责人，采购电力二次系统生产控制大区中的安全产品，厂家向电站提供相应产品并具有国家制定机构的安全监测证明。	5
	自行软件开发	a) 应确保开发环境与实际运行环境物理分开。	无自行软件开发。	N/A
		b) 应制定软件开发管理制度，明确说明开发过程的控制方法和人员行为准则。	无自行软件开发。	N/A
		c) 应确保提供软件设计的相关文档和使用指南，并由专人负责保管。	无自行软件开发。	N/A
	外包软件开发	a) 应根据开发需求检测软件质量。	形成《系统测试报告》，包括功能和性能测试方面。经访谈安全管理员，电力监控系统和光功率预测系统从厂商直接采购，软件质量符合厂站需求。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 应确保提供软件设计的相关文档和使用指南。	经访谈安全管理员，厂商提供了电力监控系统和光功率预测系统的设计文档，提供使用指南并对用户进行培训。	5
		c) 应在软件安装之前检测软件包中可能存在的恶意代码。	经访谈安全管理员，软件安装之前没有进行软件包中存在恶意代码的检测。	0
		d) 应在外包开发合同中明确开发单位、供应商所提供的电力二次设备及系统应包含保密、生命周期、禁止关键技术和设备扩散等方面的条款。	经访谈安全管理员，电力监控系统和光功率预测系统采购由上级单位负责，合同中明确了系统应包含的保密、生命周期、禁止关键技术和设备扩散等方面的条款。	5
		e) 外包开发的软件应在本单位存有源代码备份，并已通过软件后门等安全性检测。	经访谈安全管理员，厂商未提供电力监控系统和光功率预测系统的软件源代码备份。	0
	工程实施	a) 应指定或授权专门的部门或人员负责工程实施过程的管理。	经访谈安全负责人，工程全程由安全管理员负责实施全过程。	5
		b) 应制定详细的工程实施方案，控制工程实施过程。	经访谈安全负责人，查看《项目实施管理制度》及施工方案，由安全管理员审核施工所使用的详细方案，并进行施工进度控制，检查施工的合规性。并由厂家提供阶段性报告，每天进行日报工作票的填写。	5
	测试验收	a) 应对系统进行安全性测试验收。	经访谈安全负责人及查看相关的测试报告，得知国网甘肃省电力公司组织 8 个部门的专家对系统进行安全性测试。	5
		b) 在测试验收前应根据设计方案或合同要求等制订测试验收方案，在测试验收过程	在测试验收前根据设计方案和合同要求等制定《系统测试方案》，在测试验收过程中详	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		中应详细记录测试验收结果，并形成测试验收报告。	细记录测试验收结果。经访谈安全管理员及查看由厂家提供实施过程中的记录文件，形成验收报告，由电站安全负责人进行设计方案及合同的审核，然后发送上级单位及调度审核，全部通过后验收通过。	
		c) 应组织相关部门和相关人员对系统测试验收报告进行审定，并签字确认。	经访谈安全负责人及查看了验收报告，电站组织安全责任人和安全管理员进行项目验收，然后发送给上级单位及调度进行验收，全部通过后验收通过。	5
	系统交付	a) 应制定系统交付清单，并根据交付清单对所交接的设备、软件和文档等进行清点	制定系统交付清单，并根据交付清单对所交接的设备、软件和文档等进行清点。经访谈安全负责人及查看相关的系统交付清单，并根据交付清单对所交接的设备、软件和文档等进行清点。	5
		b) 应对负责系统运行维护的技术人员每年进行相应的技能培训,对安全教育和培训的情况和结果进行记录并归档保存。	经查看《人事管理制度》、《年度信息安全培训计划》，对厂商运维人员进行进场前安全培训，并形成培训记录，培训人员签字确定，并签署保密协议和安全协议。	5
		c) 应确保提供系统建设过程中的文档和指导用户进行系统运行维护的文档。	经访谈安全管理员，厂商提供运维方案，并交接安全负责人，安全负责人录制视频留存。	5
	安全服务商选择	a) 应选择符合国家及行业有关规定的服务商开展安全服务。	经访谈安全管理员，选择服务商选择符合国家及行业有关规定的服务商开展安全服务，并告知上级单位及调度进行可行性研究。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 应与选定的安全服务商签订安全协议，明确安全责任	经访谈安全管理员，与建设的安全厂商签署合同、保密协议、安全协议、违约责任等。	5
		c) 应与服务商签订安全服务合同，确保提供技术培训，并明确服务承诺。	经访谈安全管理员，电站与安全服务商签署服务合同，合同内容符和合同标准需要的服务期限，且双方签字盖章，并签署保密协议和安全协议。	5

A.10 系统运维管理

测评对象	安全控制点	测评指标	结果记录	符合程度
系统运维		a)应指定专门的部门或人员定期对机房供配电、空调、温湿度控制等设施进行维护	访谈机房管理员，有专门的人员不定期对机房供配电、精密空调、温湿度控制等设施进行表》。查看《光伏发电站电力监控系统运维管理规定》中明确提出了对信息系统的上线前应进行全面的测试以及整改加固，通过测试后才能上线试运行。	5
		b) 应配备机房安全管理人员，对机房的出入、服务器的开机或关机等工作进行管理。	访谈机房管理员，现场有专人负责机房安全。查看《光伏发电站电力监控系统安全防护管理制度》明确规定进入机房必须填写《机房出入场登记记录表》，对服务器的开机或关机等工作有专人进行管理。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		c) 应建立机房安全管理制度，对有关机房物理访问，物品带进、带出机房和机房环境安全等方面的管理作出规定。	查看《电力监控系统运维管理规定》，规定机房内物理访问接入需进行审批，禁止带出机房内设备，操作完成保证现场整洁，带入设备需部门领导审批。经查看《光伏发电站电力监控系统安全防护管理制度》，对有关机房物理访问，物品带进、带出机房和机房环境安全等方面的管理作出规定。	5
		d)应加强对办公环境的保密性管理，包括工作人员调离办公室应立即交还该办公室钥匙和不在办公区接待来访人员等。	查看《电力监控系统安全防护岗位职责》制定有完善的办公环境管理制度，对工作人员离开座位时退出登录状态/桌面没有敏感信息文件、不在办公区接待来访人员等方面作出规定。访谈安全管理员，在明确规定了人员调离时其使用和保管的各种证件、钥匙、USBKey、涉密文件、技术资料等进行清查登记并归还，由光伏电站注销其用户帐号和授权。	5
	资产管理	a)应编制与信息系统相关的资产清单，包括资产责任部门、重要程度和所处位置等内容。	查看《电力监控系统设备台账》制定了与电力监控系统相关的完善的资产台账，所有台账分级分类进行管理。访谈网络安全管理员，有《光伏发电站台账管理制度》对于资产的管理作了详细说明，对资产的设备名称、设备型号、设备序列号、机房位置、配置分类、操作系统等做了登记。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		b) 应建立资产安全管理制度，规定信息系统资产管理的责任人员或责任部门，并规范资产管理和使用的行为。	经查看《光伏发电站台账管理制度》中建立了资产安全管理制度，规定了信息系统资产管理的部门为光伏发电站，对资产管理和使用的行为进行规范。	5
	介质管理	a)应建立生产控制大区移动存储介质安全管理制度，对移动存储介质的使用进行严格限制。	查看《电力监控系统设备台账》建立了生产控制大区移动存储介质安全管理制度，对移动存储介质的使用进行了严格限制。 公司制定了《光伏发电站电力监控系统安全防护移动介质管理制度》，对介质的存放环境、使用、维护和销毁等管理方面作出规范和说明。	5
		b)应确保介质存放在安全的环境中，对各类介质进行控制和保护，并实行存储环境专人管理。	经查看《光伏发电站电力监控系统安全防护移动介质管理制度》，中对于介质的存放环境和控制保护作出了明确规定，对于存储介质的带出/带入有明确的手续，能够有效防止介质被盗、被毁、非法泄露和篡改等情况的发生。	5
		c)应对介质归档和查询等过程进行记录，并根据存档介质的目录清单定期盘点。	查看《电力监控系统设备台账》对介质归档和查询等过程进行了控制，形成记录，并定期进行盘点。经查看《光伏发电站电力监控系统安全防护移动介质管理制度》中明确了对使用的涉密移动存储介质进行检查、核对，并做出文字或电子记录，发现丢失的会及时查处。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		d)应对需要送出维修或销毁的介质，首先清除其中的敏感数据，防止信息的非法泄漏。	经访谈安全管理员，在使用过程中对于送出维修以及销毁的存储介质，资产管理员会送出维修，并且填写《光伏发电站电力监控系统涉密移动存储介质外修申请表》。对于要销毁的介质会首先清除介质中的敏感数据，对于保密性较高的存储介质会向主管领导发起审批，待批准后进行销毁。	5
		e) 应根据所承载数据和软件的重要程度对介质进行分类和标识管理。	查看《电力监控系统设备台账》，并现场查看介质，有专人保管，重要数据和软件采用加密硬盘进行存储，并进行分类和标识管理。经查看《光伏发电站电力监控系统安全防护移动介质管理制度》中规定对不同介质进行了不同的分类和标识。	5
	设备管理	a)应对信息系统相关的各种设备（包括备份和冗余设备）、线路等指定专门的部门或人员定期进行维护管理。	查看《机房保护室人员出入登记表》，由光伏电站的相关人员对电力监控系统的相关设备进行维护。信息系统设备包括各种服务器、终端计算机、工作站、便携机、网络设备、安全设备、存储设备等。	4
		b) 应建立基于申报、审批和专人负责的设备安全管理制度，对信息系统的各种软硬件设备的选型、采购、发放和领用等过程进行规范化管理。	查看《产品采购管理制度》有详细的设备安全管理制度，对设备的申报、审批进行管理。经访谈物资管理员，由五合光伏电站物资主管填写《物资采购申请表》向上级单位申请，上级单位对各类软硬件设备的选型、采购、发放和领用等	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			过程进行审批。	
		c) 应对终端计算机、工作站、便携机、系统和网络等设备的操作和使用进行规范化管理，按操作规程实现关键/主要设备（包括备份和冗余设备）的启动/停止、加电/断电等操作。	制定《网络设备及服务器操作规程》、《网络安全管理制度主要设备的操作规程，包括安全认证网关、密码机、入侵检测设备等安全设备、网络设备。查看《电力监控系统安全防护管理制度》，查看留存的工作票，查看电力监控系统的操作手册要求，对所有相关设备进行管理。经查看《光伏发电站电力监控系统安全防护管理制度》中对计算机系统管理制度明确了对主要服务器、防火墙、加密设备的操作流程。	5
		d)应确保信息处理设备必须经过审批才能带离机房或办公地点。	查看《电力监控系统运维管理规定》，所有设备带出机房和办公地点都需要专人陪同，经过审批后带出。《机房设备进出单》是设备带离光伏发电站的申报材料和审批报告。访谈机房管理员，信息处理设备带离机房需经过安全主管审批，但无相关制度。	3
		e) 应确保信息处理设备必须经过审批才能带入机房或办公地点。	查看《电力监控系统运维管理规定》，查看《电力监控系统设备台账》，所有设备带入机房和办公地点都需要专人陪同，经过审批后带入。经访谈机房管理员，信息处理设备带入机房需经过安全主管审批，	3

测评对象	安全控制点	测评指标	结果记录	符合程度
			但无相关制度。	
	网络安全管理	a) 应指定人员/专人对网络进行管理，负责运行日志、网络监控记录的日常维护和报警信息分析和处理工作。	经访谈网络安全管理员，没有指定人员对网络日志、网络监控记录进行分析和处理。	0
		b) 应建立网络安全管理制度，对网络安全配置、日志保存时间、安全策略、升级与打补丁、口令更新周期等方面作出规定。	《电力监控系统安全防护管理制度》中包含网络安全配置、安全策略、升级与打补丁授权访问、日志保存时间、口令更新周期、文件备份等方面的内容。经查看《光伏发电站电力监控系统安全防护方案》中规定了安全策略管理，定期对系统进行安全风险评估。经查看《光伏发电站电力监控系统安全防护管理制度》中规定口令长度不小于 8 位，为字母+数字混合方式，更换周期为三个月。	5
		c) 应根据厂家提供的软件升级版本对网络设备进行更新，并在更新前对现有的重要文件进行备份。	经访谈系统管理员，网络设备由公司统一进行更新，并在更新前对现有的重要文件进行备份。	5
		d) 应定期对网络系统进行漏洞扫描，对发现的网络系统安全漏洞进行及时的修补。	经访谈系统管理员，光伏发电站电力监控系统未对网络系统进行漏洞扫描。	0
		e) 应对网络设备的配置文件进行定期备份。	经访谈系统管理员，网络设备配置文件在设备安装时由厂家进行备份，无定期备份。	0

测评对象	安全控制点	测评指标	结果记录	符合程度
		f) 应保证所有与外部系统的连接均得到授权和批准。	经查看《光伏发电站电力监控系统安全防护远程访问管理制度》中有申请流程，需管理员和部门领导授权和批准。	5
	系统安全管理(G2)	a) 应根据业务需求和系统安全分析确定系统的访问控制策略。	经访谈系统管理员，信息系统、文件及服务均按照最小化权限原则给予分配，制定《主机安全管理制度》，明确说明根据业务需求和系统安全分析确定系统的访问控制策略等相关内容。	5
		b) 应定期进行漏洞扫描，对发现的系统安全漏洞及时进行修补。	经访谈系统管理员，没有定期对系统进行漏洞扫描，无漏洞扫描报告。	0
		c) 应安装系统的最新补丁程序，在安装系统补丁前，首先在测试环境中测试通过，并对重要文件进行备份后，方可实施系统补丁程序的安装。	经访谈系统管理员，由厂家对系统不定期安装补丁，补丁安装前经厂家在测试环境中通过测试，并对重要文件进行备份后实施系统补丁程序的安装。	5
		d) 应建立系统安全管理制度，对系统安全策略、安全配置、日志管理和日常操作流程等方面作出具体规定。	经访谈系统管理员，没有建立系统安全管理制度，系统安全策略和安全配置均由厂家完成。厂家进行日志管理。	0
		e) 应依据操作手册对系统进行维护，详细记录操作日志，包括重要的日常操作、运行维护记录、参数的设置和修改等内容，严禁进行未经授权的操作。	形成《系统需求开发事项确认单》、《操作申请单》，对重要的日常操作、运行维护记录、参数的设置和修改等内容进行记录。查看《电力监控系统安全防护岗位职责》，查看设备维护记录。经访谈系统管理员，设备由厂家维护，系统根据操作手册进行维护，有详细操作日志，所有操作需开具	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			电力行业工作票方可实行。	
		f) 应定期对运行日志和审计数据进行分析，以便及时发现异常行为。	经访谈系统管理员，没有定期对运行日志和审计数据进行分析，厂家不定期会查看运行日志和审计数据进行分析。	0
		g) 电力调度机构应指定专人负责管理本级调度数字证书系统。	经访谈系统管理员，数字证书由电力公司统一下发、由安全主管统一管理。	5
	恶意代码防范管理	a) 应提高所有用户的防病毒意识，及时告知防病毒软件版本，在读取移动存储设备上的数据以及网络上接收文件或邮件之前，先进行病毒检查，对外来计算机或存储设备接入网络系统之前也应进行病毒检查。	经访谈安全管理员，所有接入电站数据网络中的设备，务必需通过安全管理员及站长的审批，并查看其设备的杀毒软件病毒库和扫描记录，没有杀毒软件需提供病毒扫描记录。	5
		b) 在更新恶意代码库、木马库以及 IDS 规则库前，应首先在测试环境中测试通过，更新操作应离线进行，生产控制大区恶意代码更新应由专人负责，并保存更新记录	更新代码库和木马库前，由供应商在测试环境中对代码库进行测试。经访谈系统管理员，系统没有恶意代码防护，没有 IDS 等相关安全类设备。	0
		c）应指定专人对网络和主机进行恶意代码检测并保存检测记录。	经访谈系统管理员，没有对系统进行恶意代码检测，没有检测记录。	0
		d) 应对防恶意代码软件的授权使用、恶意代码库升级定期汇报等作出明确规定。	经访谈系统管理员，系统没有安装防恶意代码软件。	0
	密码管理	a)应建立密码使用管理制度，使用符合国家密码管理规定的密码技术和产品。	密码技术和产品的使用是否遵照国家密码管理规定。制定《密码设备管理制度》对密码产品的使用进行规范。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
	变更管理	a) 应确认系统中要发生的变更，并制定变更方案。	经访谈系统管理员，系统变更没有管理制度规定。	0
		b) 系统发生重要变更前，应向主管领导申请，审批后方可实施变更，并在实施后向相关人员通告。	经访谈系统管理员，系统发生变更前根据变更规模，须提交相关负责人或领导进行评审和审批。经访谈系统管理员，系统变更由厂商负责提供实施方案，由上级单位审核通过后，下发许可，实施结束后以文件及会议模式向相关人员进行宣贯。	5
	备份和恢复管理	a) 应识别需要定期备份的重要业务信息、系统数据及软件系统等。	经访谈系统管理员，光功率预测数据每隔两天进行一次数据备份，设备配置数据在设备安装时由厂商负责备份并交由厂站留存。	5
		b) 应建立备份与恢复管理相关的安全管理制度，对备份信息的备份方式、备份频度、存储介质和保存期等进行规范。	制定《数据备份与恢复管理办法》，对备份信息的备份方式备份频度、存储介质和保存期等进行规范和说明。经查看《光伏发电站电力监控 系统数据备份与恢复制度》规定，备份方式采用离线备份， 关键数据至少两天备份一次，存储介质至少两份，备份数据永久保存。	5
		c)应根据数据的重要性和数据对系统运行的影响，制定数据的备份策略和恢复策略，备份策略须指明备份数据的放置场所、文件命名规则、介质替换频率和将数据离站运输的方法。	制定《介质安全管理规定》，根据数据的重要性和数据对系统运行的影响，明确了数据的存放场所、文件命名规则、介质替换频率、数据离站传输方法等方面的规定。经查看，《光伏发电站电力监控系统数据备份与恢复制度》制定了数据的备份策略和恢复策略，《数据备份登记簿》详	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			细记录备份名称、内容、时间备份数据交由档案管理员并设立专柜分类存放。	
	安全事件处置	a) 应报告所发现的安全弱点和可疑事件，但任何情况下用户均不应尝试验证弱点。	报告所发现的安全弱点和可疑事件，任何情况下用户均不尝试验证弱点。经访谈系统运维负责人，用户发现安全弱点和可疑事件时应及时向安全主管报告。	5
		b) 应制定安全事件报告和处置管理制度，明确安全事件的类型，规定安全事件的现场处理、事件报告和后期恢复的管理职责。	制定《安全管理事件管理制度》，明确安全事件的类型，规定安全事件的现场处理、事件报告和后期恢复的管理职责等内容。查看《电力监控系统安全防护管理制度》，制定了完善的安全事件处置制度，明确了安全事件的上报、处置流程。经访谈系统管理员，当发现安全事件时，及时汇报安全主管，由安全主管安排人员及时处理，但无相关管理制度。	3
		c) 应根据国家相关管理部门对计算机安全事件等级划分方法和安全事件对本系统产生的影响，对本系统计算机安全事件进行等级划分。	制定《安全事件管理制度》，按照信息系统影响程度对安全事件划分为重大、较大、一般三个事件级别，确定安全事件的定义、安全事件等级划分原则、等级描述等方面内容。查看《电力监控系统安全防护管理制度》，按照电力行业要求对安全事件等级进行了划分。经访谈系统管理员，依据《国家电网公司安全事故调查规程》规定，相对应事件处置流程需满足电力行业规定完成处置，并上报调度。	5

测评对象	安全控制点	测评指标	结果记录	符合程度
		d）应记录并保存所有报告的安全弱点和可疑事件，分析事件原因，监督事态发展，采取措施避免安全事件发生。	制定《安全事件管理制度》，根据不同安全事件制定不同的响应和处置的范围、程度、处理方法，明确具体报告方式、报告内容、报告人等方面内容。经访谈网络安全管理员，根据电力调度下发整改事件要求，电厂需提供引起此安全事件的原因，并进行处理此事件的过程记录及避免再次发生此类问题的方法，然后报送调度留存。	5
		e) 应建立电力二次系统联合防护和应急机制，负责处置跨部门电力二次系统安全事件。	经访谈电站负责人，电站为统一安全责任人进行管理，不涉及库部门电力二次系统安全事件，并且电站独立成域，并无跨部门。	5
	应急预案管理	a) 应在统一的应急预案框架下制定不同事件的应急预案，应急预案框架应包括启动应急预案的条件、应急处理流程、系统恢复流程、事后教育和培训等内容。	查看《信息安全分类应急预案》，其内容包括应急预案的条件，应急处理流程，在确保信息系统可能发生的安全事件，在最短时间内得到妥善处置，将影响降低到最小。	5
		b）应制定电力二次系统联合防护和应急处置预案，并经过演练。	访谈系统管理员，没有建立电力系统联合防护和应急预案，也没有进行过演练。	0
		c) 应对安全管理员、系统管理员、网络管理员等相关的人员进行应急预案培训，应急预案的培训应至少每年举办一次。	《信息安全分类应急预案》，包括系统安全隐患（网络、操作系统与数据库、网络应用、数据、管理）、系统重大事件的界定、系统重大事件的应急预案（电源、网络主机存储以及数据库、电脑病毒）等。查看培训记录，对安全管理员，系统管理员和网络管理员每年至少举办一次应急预案培	5

测评对象	安全控制点	测评指标	结果记录	符合程度
			训，并形成培训记录。	

A.11 特殊指标安全层面

无特殊指标。

A.12 自愿放弃验证测试声明